



**CYBER; CRA;
Essential cybersecurity requirements for routers, modems
intended for the connection to the internet, and switches**

Reference

DEN/CYBER-EUS-0013

Keywords

CRA; Cybersecurity; router, modem, switch

CAUTION:

Exercising one of the Principles of international standardization – Openness – and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit: <https://labs.etsi.org/rep/stan4cra/> and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](https://docbox.etsi.org/CYBER/EUSR/Open)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm except as authorized by written permission of ETSI.

The content of the PDF version shall not be modified without the written authorization of ETSI.

The copyright and the foregoing restriction extend to reproduction in all media.

© ETSI 2025.
All rights reserved.

Contents

38			
39	Intellectual Property Rights	9	
40	Foreword.....	9	
41	Modal verbs terminology	9	
42	Executive summary	10	
43	Introduction	10	
44	1 Scope	11	
45	2 References	11	
46	2.1 Normative references.....	11	
47	2.2 Informative references	11	
48	3 Definition of terms, symbols and abbreviations.....	12	
49	3.1 Terms	12	
50	3.2 Symbols	14	
51	3.3 Abbreviations.....	14	
52	4 Product context.....	14	
53	4.1 Introduction.....	14	
54	4.2 Routers.....	15	
55	4.3 Modems intended for connection to the internet.....	15	
56	4.4 Switches.....	15	
57	4.5 Product architecture and components	16	
58	5 Applicability model.....	16	
59	5.1 General.....	16	
60	5.2 Capability-based conditions.....	17	
61	5.2.1 Introduction	17	
62	5.2.2 Management access exposure conditions.....	17	
63	5.2.3 Management operational model conditions.....	18	
64	5.2.4 Protocol and service conditions.....	18	
65	5.3 Condition Assessment.....	18	
66	5.3.1 General	18	
67	5.3.2 Content requirements	18	
68	5.3.3 Completeness	19	
69	5.3.4 Maintenance of the Condition Assessment	19	
70	5.4 Undeclared or misdeclared conditions.....	19	
71	6 Cybersecurity requirements.....	19	
72	6.1 General.....	19	
73	6.2 Secure by Design	20	
74	6.2.1 General	20	
75	6.2.1.1 Input.....	20	
76	6.2.1.2 Requirements.....	20	
77	6.2.1.3 Output.....	20	
78	6.2.1.4 Assessment criteria.....	20	
79	6.3 No Known Vulnerabilities	20	
80	6.3.1 General	20	
81	6.3.1.1 Input.....	20	
82	6.3.1.2 Requirements.....	20	
83	6.3.1.3 Output.....	21	
84	6.3.1.4 Assessment criteria.....	21	
85	6.4 Secure by Default Configuration	21	
86	6.4.1 General	Error! Bookmark not defined.	
87	6.4.2 [DEFAULT] Secure by default configuration.....	21	
88	6.4.2.1 General	21	
89	6.4.2.2 Input.....	21	
90	6.4.2.3 Requirements	21	

91	6.4.2.4	Output.....	22
92	6.4.2.5	Assessment criteria.....	22
93	6.4.3	[RESET] Factory reset.....	22
94	6.4.3.1	General.....	22
95	6.4.3.2	Input.....	22
96	6.4.3.3	Requirements.....	22
97	6.4.3.4	Output.....	23
98	6.4.3.5	Assessment criteria.....	23
99	6.5	Security Updates.....	23
100	6.5.1	General.....	Error! Bookmark not defined.
101	6.5.2	[UPDATE] Update mechanisms.....	23
102	6.5.2.1	General.....	23
103	6.5.2.2	Input.....	23
104	6.5.2.3	Requirements.....	23
105	6.5.2.4	Output.....	24
106	6.5.2.5	Assessment criteria.....	24
107	6.6	Access Control.....	25
108	6.6.1	General.....	Error! Bookmark not defined.
109	6.6.2	[AUTH-1] Authentication.....	25
110	6.6.2.1	General.....	25
111	6.6.2.2	Input.....	25
112	6.6.2.3	Requirement.....	25
113	6.6.2.4	Output.....	26
114	6.6.2.5	Assessment criteria.....	26
115	6.6.3	[AUTH-2] Authorization.....	26
116	6.6.3.1	General.....	26
117	6.6.3.2	Input.....	26
118	6.6.3.3	Requirements.....	26
119	6.6.3.4	Output.....	27
120	6.6.3.5	Assessment criteria.....	27
121	6.6.4	[AUTH-3] Authenticated session lifecycle.....	27
122	6.6.4.1	General.....	27
123	6.6.4.2	Input.....	27
124	6.6.4.3	Requirements.....	27
125	6.6.4.4	Output.....	28
126	6.6.4.5	Assessment criteria.....	28
127	6.6.5	[AUTH-4] Protocol access control.....	28
128	6.6.5.1	General.....	28
129	6.6.5.2	Input.....	28
130	6.6.5.3	Requirements.....	28
131	6.6.5.4	Output.....	29
132	6.6.5.5	Assessment criteria.....	29
133	6.7	Data Protection.....	29
134	6.7.1	General.....	29
135	6.7.2	Input.....	29
136	6.7.3	Requirements.....	30
137	6.7.4	Output.....	30
138	6.7.5	Assessment criteria.....	30
139	6.8	Availability and Resilience.....	30
140	6.8.1	General.....	30
141	6.8.2	Input.....	30
142	6.8.3	Requirements.....	31
143	6.8.4	Output.....	31
144	6.8.5	Assessment criteria.....	31
145	6.9	Attack Surface and Mitigation.....	31
146	6.9.1	General.....	Error! Bookmark not defined.
147	6.9.2	[INTEGRITY] System integrity and boot process.....	31
148	6.9.2.1	General.....	31
149	6.9.2.2	Input.....	31
150	6.9.2.3	Requirements.....	31
151	6.9.2.4	Output.....	32
152	6.9.2.5	Assessment criteria.....	32

153	6.9.3	[PACKET] Default packet disposition.....	32
154	6.9.3.1	General	32
155	6.9.3.2	Input.....	33
156	6.9.3.3	Requirements.....	33
157	6.9.3.4	Output.....	33
158	6.9.3.5	Assessment criteria.....	33
159	6.9.4	[EXPOSURE] Interface and service exposure minimization.....	33
160	6.9.4.1	General	33
161	6.9.4.2	Input.....	33
162	6.9.4.3	Requirements.....	34
163	6.9.4.4	Output.....	34
164	6.9.4.5	Assessment criteria.....	34
165	6.10	Monitoring and Logging.....	34
166	6.10.1	General	34
167	6.10.1.1	Input.....	34
168	6.10.1.2	Requirements.....	34
169	6.10.1.3	Output.....	35
170	6.10.1.4	Assessment criteria.....	35
171	6.11	Data Management.....	35
172	6.11.1	General	Error! Bookmark not defined.
173	6.11.2	[TRANSFER] Secure data export and transfer	35
174	6.11.2.1	General	35
175	6.11.2.2	Input.....	35
176	6.11.2.3	Requirements.....	35
177	6.11.2.4	Output.....	35
178	6.11.2.5	Assessment criteria.....	35
179	7	Vulnerability Handling Requirements.....	35
180	7.1	General.....	35
181	7.2	Vulnerability identification and documentation.....	36
182	7.2.1	General	36
183	7.2.1.1	Input.....	36
184	7.2.1.2	Requirements.....	36
185	7.2.1.3	Output.....	36
186	7.2.1.4	Assessment criteria.....	36
187	7.3	Vulnerability Remediation.....	36
188	7.3.1	General	36
189	7.3.1.1	Input.....	36
190	7.3.1.2	Requirements.....	36
191	7.3.1.3	Output.....	36
192	7.3.1.4	Assessment criteria.....	36
193	7.4	Security testing and review.....	36
194	7.4.1	General	36
195	7.4.1.1	Input.....	37
196	7.4.1.2	Requirements.....	37
197	7.4.1.3	Output.....	37
198	7.4.1.4	Assessment criteria.....	37
199	7.5	Vulnerability disclosure.....	37
200	7.5.1	General	37
201	7.5.1.1	Input.....	37
202	7.5.1.2	Requirements.....	37
203	7.5.1.3	Output.....	37
204	7.5.1.4	Assessment criteria.....	37
205	7.6	Coordinated vulnerability disclosure policy	37
206	7.6.1	General	37
207	7.6.1.1	Input.....	37
208	7.6.1.2	Requirements.....	37
209	7.6.1.3	Output.....	37
210	7.6.1.4	Assessment criteria.....	37
211	7.7	Vulnerability reporting mechanisms.....	37
212	7.7.1	General.....	37
213	7.7.1.1	Input.....	38

214	7.7.1.2	Requirements	38
215	7.7.1.3	Output	38
216	7.7.1.4	Assessment criteria	38
217	7.8	Update distribution	38
218	7.8.1	General	38
219	7.8.1.1	Input	38
220	7.8.1.2	Requirements	38
221	7.8.1.3	Output	38
222	7.8.1.4	Assessment criteria	38
223	7.9	Security advisory and user guidance	38
224	7.9.1	General	38
225	7.9.1.1	Input	38
226	7.9.1.2	Requirements	38
227	7.9.1.3	Output	38
228	7.9.1.4	Assessment criteria	38
229	Annex A (informative): Relationship between the present document and the requirements of EU		
230	Regulation [Reference numbers of legislation]39		
231	8	Annex B (normative): Condition Assessment.....	43
232	8.1	Instructions for completion	43
233	8.1.1	Assessment categories	43
234	8.1.2	Assessment principles	43
235	8.2	Condition Assessment Template.....	43
236	9	Annex C (informative): Product deployment contexts and use cases	44
237	9.1	Use cases and deployment scenarios	44
238	9.1.1	Residential deployments	44
239	9.1.2	Small and medium enterprise deployments.....	44
240	9.1.3	Enterprise and data center deployments	44
241	9.1.4	Critical infrastructure and industrial deployments	44
242	9.1.5	Service provider and carrier networks.....	44
243	9.1.6	Cloud and virtualized environments.....	45
244	9.2	Product essential functions	45
245	9.2.1	Network traffic forwarding and routing	45
246	9.2.2	Network protocol implementation.....	45
247	9.2.3	Access control and security policy enforcement	45
248	9.2.4	Configuration and management	46
249	9.2.5	Monitoring and diagnostics	46
250	9.3	Operational environment	46
251	9.4	User categories and access context	46
252	9.5	Product security context summary	47
253	10	Annex D (informative): Threat landscape and security considerations	48
254	10.1	General.....	48
255	10.2	Threat agent characterization.....	48
256	10.2.1	Threat distribution across network exposure levels	48
257	10.2.2	Threat patterns associated with management models.....	49
258	10.2.3	Threats arising from capability-based conditions.....	49
259	10.2.4	Advanced persistent threats and emerging attack vectors	50
260	10.2.4.1	Nation-state actors and Advanced Persistent Threat groups.....	50
261	10.2.4.2	Supply chain infiltration threats.....	51
262	10.2.4.3	Zero-day exploit markets and commercialization.....	51
263	10.3	Vulnerability analysis	51
264	10.3.1	Attack scenario analysis	52
265	10.3.2	Condition-based threat exposure	52
266	11	Annex E (informative): Risk assessment framework.....	54
267	11.1	General.....	54
268	11.2	Primary risk dimensions	54
269	11.2.1	Compromise likelihood factors	54
270	11.2.2	Impact severity factors	55
271	11.2.3	Systemic and cascade risk factors	55

272	11.2.4	Temporal and lifecycle risk evolution.....	55
273	11.2.5	Operational and organizational risk factors.....	56
274	11.2.6	Risk assessment synthesis	56
275	11.2.6.1.1.1.1.1	Annex <L+1> (informative): Maximum measurement uncertainty	58
276	11.2.6.1.1.1.1.2	Annex <L+2> (normative or informative): Title of annex	59
277	12	<L+2.1>..... First clause of the	
278		annex	59
279	12.1	<L+2.1.1>	First subdivided clause of the
280		annex.....	59
281	12.1.1.1.1.1.1.1	Annex <L+3> (informative): Bibliography	60
282	12.1.1.1.1.1.1.2	Annex <L+4> (informative): Change history.....	61
283	13	History.....	62
284			
285			

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: "*Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards*", which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

1.1.1.1.1 Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTETM** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cybersecurity (TC CYBER) and is now submitted for the combined Public Enquiry and Vote phase of the ETSI EN Approval Procedure.

The present document has been prepared in response to the Commission's standardisation request C(2025)618 [i.3] to provide, in additions to its other uses, one voluntary means of conforming to the essential requirements of Regulation (EU) 2024/2847 [i.2] known as the Cyber Resilience Act (CRA). It corresponds to the new deliverable in line 27 of Annex I of the standardisation request.

Once the present document is cited in the Official Journal of the European Union under Regulation (EU) 2024/2847 [i.2], conformance with the normative clauses of the present document given in the table(s) in Annex A confers, to products with digital elements in the scope of the present document, a presumption of conformity with the corresponding essential requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

The Technical Body should advise the ETSI Secretariat if the above default national transposition dates are inappropriate for the particular standard.

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Executive summary

"Executive summary" clause should be deleted if not necessary.

Introduction

This Harmonised European Standard defines cybersecurity requirements applicable to routers, modems intended for the connection to the internet, and switches, as identified in Annex III, Class I, point 12 of Regulation (EU) 2024/2847, the Cyber Resilience Act.

The present document supports compliance with Regulation (EU) 2024/2847, the Cyber Resilience Act, specifically addressing the essential cybersecurity requirements defined in Annex I, Parts I and II. The mapping of the minimum Cyber Resilience Act requirements with the technical requirements of the present document are explicitly detailed in Annex A.

Requirements in the present document implement a risk-based approach through conditional applicability to ensure security measures proportionate to deployment context and threat exposure. The requirements apply to all deployment forms of routers, modems intended for connection to the internet, and switches when used for their intended purpose of establishing and managing network connectivity, including standalone physical appliances, integrated multi-function products, virtualized network functions, and software-defined networking implementations.

1 Scope

The present document specifies essential cybersecurity requirements and assessment criteria for products with digital elements comprising routers, modems intended for connection to the internet, and switches, as set out in CRA Annex III, Class I, point 12. The document addresses the essential cybersecurity requirements of CRA Annex I, Part I and Part II.

NOTE: The term "internet" as used in this standard refers to any public network infrastructure accessible beyond organizational boundaries. Public networks are those accessible to multiple organizations or the general public, while private networks operate under single organizational control.

Whether deployed as dedicated hardware, virtual machines, containerized applications, or cloud-native network functions, routers, modems intended for connection to the internet, and switches fall within the scope of this standard when they provide management capabilities. This applies when their intended purpose or reasonably foreseeable use involves processing, forwarding, or managing network traffic between devices, network segments, or between public and private networks.

NOTE: Unmanaged products that operate with fixed functionality and provide no configuration interface or administrative access are excluded from the scope of this standard, as they lack the necessary interfaces to implement the security controls specified herein.

The present document does not specify functional conformance requirements for networking protocols, nor does it address performance specifications, quality of service metrics, or protocol interoperability testing. However, security controls governing the implementation of networking protocols and vulnerability management for those implementations remain within scope.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- [1] HORIZONTAL STANDARDS TO BE REFERENCED NORMATIVELY IF AND WHEN AVAILABLE AND APPROPRIATE
- [2] MISSING REFS TO OTHER STF701 WIs (firewalls, network interfaces, operating systems, etc).
- [x] <Standard Organization acronym> <document number> (<version number>): "<Title>".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding but are not required for conformance to the present document.

- [i.1] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (Text with EEA relevance)

[Regulation - 2024/2847 - EN - EUR-Lex](#)

- [i.2] Commission Implementing Regulation (EU) **.../...of XXX** on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council (Text with EEA relevance)

- [i.3] C(2025)618 – Standardisation request M/606: Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

https://ec.europa.eu/growth/tools-databases/enorm/mandate/606_en

- [i.4] NIST Cybersecurity Framework (CSF) 2.0

- [i.5] NIST SP 800-63-4 Digital Identity Guidelines

- [i.6] NIST SP 800-153 Guidelines for Securing Wireless Local Area Networks (WLANs)

- [i.7] NIST Special Publication 800-53, Security and Privacy Controls for Information Systems and Organizations (Rev. 5)

- [i.8] NIST Special Publication 800-189 Resilient Interdomain Traffic Exchange: BGP Security and DDoS Mitigation

- [i.9] ISO/IEC 15408-1:2022 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security

- [i.10] ISO/IEC 27035-1:2023 Information technology — Information security incident management

- [i.11] ISO/IEC 15408-1 Information security, cybersecurity and privacy protection — Evaluation criteria for IT security (Common Criteria)

- [i.12] ISO/IEC 19790:2025 Information security, cybersecurity and privacy protection — Security requirements for cryptographic modules

- [i.13] ISO/IEC 24759:2025 Information security, cybersecurity and privacy protection — Test requirements for cryptographic modules

- [i.14] ISO/IEC 16500-6:1999: "Information technology Generic digital audio-visual systems"

- [i.15] BSI TR-03148: "Secure Broadband Router"

- [i.16] ETSI EN 303 645 V2.1.1 (2020-06): "CYBER; Cyber Security for Consumer Internet of Things: Baseline Requirements "

- [i.x] <Standard Organization acronym> <document number> (<version number>): "<Title>".

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the following terms apply:

audit event: A timestamped record of security-relevant activities including authentication attempts, configuration changes, system events, and administrative actions, formatted in a structured manner suitable for monitoring and forensic analysis.

broadcast loop: network condition where broadcast frames continuously circulate between interconnected devices without a defined termination point, causing network degradation or failure through excessive bandwidth consumption and processing overhead.

critical security parameter: security-related confidential information whose disclosure or modification can compromise the security of the product.

EXAMPLE: Secret cryptographic keys, authentication values such as passwords, PINs, private components of certificates. debug interface: physical interface used by the manufacturer to communicate with the product during development or to perform triage of issues with the product and that is not used as part of the consumer-facing functionality

EXAMPLE: Test points, UART, SWD, JTAG.

logical interface: virtual interface used to communicate with the product at a logical layer.

NOTE 1: Typically, the semantic, syntactic, and symbolic attributes of information flows for logical interfaces are specified. The are alternative definitions for logical interfaces e.g. in ISO/IEC 16500-6:1999 [i.11] that utilize this property.

NOTE 2: A logical interface may utilize a network interface to exchange information with remote endpoints.

network interface: physical interface that can be used to access the functionality of router, modem or switch via a network.

private network: closed network within a home or an organization that is not directly accessible by the general public and is generally controlled by or on behalf of the user.

public network: a publicly accessible network like the internet and is usually not under control of the user.

router: a product with digital elements that establishes and controls the flow of data between different IP-based networks by selecting paths or routes using routing protocol mechanisms and algorithms, typically operating at the network layer.

NOTE 1: Includes but is not limited to wired and wireless routers, virtual routers and routers with or without modems.

modem intended for connection to the internet: a hardware product with digital elements that uses digital modulation and demodulation techniques to convert analogue signals from and to digital signals for IP-based communication.

NOTE 1: Includes but is not limited to fibre modems, Digital Subscriber Line (DSL) modems, cable (DOCSIS) modems, satellite modems and cellular modems.

session identifier entropy: represents the complexity of special inputs of a cryptographic algorithm used to encrypt the session.

NOTE 1: It measures the randomness and unpredictability in session identifier generation, typically expressed in bits, representing the difficulty of guessing or predicting valid session identifiers.

switch: a product with digital elements that provides IP-based connectivity between networked devices through packet forwarding mechanisms and that have a management plane, typically implemented at the data link or network layer.

NOTE 1: includes but is not limited to managed switches, smart switches, multilayer switches, virtual security switches, programmable switches for software-defined networking and bridges such as wireless access points.

firmware: software stored in non-volatile memory that controls product operation.

NOTE 1: Firmware includes boot sequences, operating system components, network protocol implementations, and management interfaces.

NOTE 2: Firmware may include persistent configuration data essential for product operation.

3.2 Symbols

For the purposes of the present document, the [following] symbols [given in ... and the following] apply:

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

API	Application Programming Interface
ARP	Address Resolution Protocol
CRA	Cyber Resilience Act
CVD	Coordinated Vulnerability Disclosure
CSAF	Common Security Advisory Framework
DDoS	Distributed Denial of Service
DHCP	Dynamic Host Configuration Protocol
DSL	Digital Subscriber Line
DNS	Domain Name System
ENISA	European Union Agency for Network and Information Security
EU	European Union
HTTP	HyperText Transfer Protocol
ICMP	Internet Control Message Protocol
IEEE	Institute of Electrical and Electronics Engineers
IoT	Internet of Things
IP	Internet Protocol
ISO	International Organization for Standardization
JTAG	Joint Test Action Group
LAN	Local Area Network
MAC	Media Access Control
MPCVD	Multi-Party Coordinated Vulnerability Disclosure
NIST	National Institute of Standards and Technology
NTP	Network Time Protocol
OSI	Open Systems Interconnection
OTP	One-Time Password
OWASP	Open Web Application Security Project
RF	Radio Frequency
SBOM	Software Bill of Materials
SE	Secure Elements
SOHO	Small Office / Home Office
SSID	Service Set Identifier
STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege
SWD	Serial Wire Debug
TEE	Trusted Execution Environment
UART	Universal Asynchronous Receiver-Transmitter
UI	User Interface
WAN	Wide Area Network
WPS	Wi-Fi Protected Setup

4 Product context

4.1 Introduction

Network products comprising routers, modems intended for connection to the internet, and switches form the fundamental building blocks of digital communications, enabling connectivity and facilitating communication across both public and private network infrastructures. These products serve as control points for data flow, implementing essential functions such as traffic routing, network address translation, or packet forwarding. Their position at network

boundaries and interconnection points makes them both essential for connectivity and attractive targets for malicious actors seeking to compromise network integrity, confidentiality, or availability.

The security posture of these products directly impacts the protection of all connected systems and data flows passing through them. A compromised product may enable malicious user to intercept communications, redirect traffic to unintended destinations, deny service to legitimate users, or use the product as a launching point for attacks on other network segments. The widespread deployment of these products across consumer, enterprise, and critical infrastructure environments necessitates security requirements that scale appropriately to different risk contexts while maintaining baseline protections for all deployments.

These products operate continuously with varying degrees of user interaction and management complexity. While modems intended for connection to the internet may function with minimal configuration after initial setup, routers and managed switches usually require ongoing administration of routing policies, access controls, and network segmentation. Despite these operational differences, all three product types share common security-critical characteristics. They process substantial volumes of network traffic, maintain operational state whether simple bridge tables or complex routing databases, and implement multiple network protocols that must interoperate. Routers manage dynamic routing protocols and maintain extensive state about network topologies and paths. Switches track MAC address associations and VLAN memberships while enforcing port-level security policies. Modems intended for connection to the internet bridge between different physical layer technologies while increasingly incorporating routing and security functions. This range of operational complexity, from simple data link layer (Layer 2 of the OSI model) forwarding to advanced traffic analysis and filtering, requires security measures that protect the fundamental traffic forwarding function while appropriately securing management interfaces and advanced features based on product capability and deployment context.

To enhance market appeal and provide greater value to potential buyers, manufacturers increasingly bundle these products with additional software features such as integrated firewall capabilities, VPN services, content filtering, quality of service management, and various network monitoring tools.

While this expanded software ecosystem aims to deliver comprehensive networking solutions and improved utility, it simultaneously introduces significant security considerations. Each additional software component represents a potential attack surface that adversaries may exploit. These supplementary features, though designed to enhance functionality and marketability, require careful security assessment and ongoing maintenance to prevent them from becoming vulnerability points that could compromise the entire network infrastructure

4.2 Routers

Routers operate at the network layer (Layer 3 of the Open Systems Interconnection (OSI) model) to establish and control data flow between different Internet Protocol (IP)-based networks through various path selection mechanisms. These products implement routing protocols and algorithms (such as Border Gateway Protocol (BGP), Open Shortest Path First (OSPF), Routing Information Protocol (RIP), and Intermediate System to Intermediate System (IS-IS)) to determine paths for packet forwarding across network boundaries, with their fundamental role being the interconnection of distinct network segments.

Modern routers incorporate extensive functionality beyond basic routing capabilities, including advanced routing protocol support, and granular traffic management suitable for complex network topologies and high-volume traffic scenarios.

4.3 Modems intended for connection to the internet

Modems intended for connection to the internet serve as the interface between private and public networks, employing digital modulation and demodulation techniques to enable IP-based communication over various physical media. These hardware products convert digital signals from network equipment into formats suitable for transmission over specific carrier technologies, whether coaxial cable networks using DOCSIS protocols, telephone lines employing DSL technologies, fiber optic cables requiring optical-to-electrical conversion, or cellular networks utilizing radio frequency modulation. Contemporary modem implementations increasingly integrate routing and switching capabilities, though their primary distinguishing function remains the physical layer conversion between private and public network transmission technologies.

4.4 Switches

Switches provide connectivity between networked products within local network segments, employing packet forwarding mechanisms to efficiently direct traffic between connected endpoints. These products operate primarily at

the data link layer (Layer 2 of the OSI model) while increasingly incorporating network layer functionality in multilayer implementations.

The present document addresses switches which have management plane capabilities that enable configuration and monitoring. Unmanaged switches with fixed functionality lack the interfaces necessary to implement the security controls specified herein. The management plane enables configuration of features present in the switch. They may include VLAN segmentation to create logical network boundaries, spanning tree protocols to prevent broadcast loops, port security to control product access, and quality of service policies to prioritize traffic flows. Switches maintain internal tables for mapping hardware addresses to physical ports, learning topology dynamically while providing mechanisms for static configuration when required. Enterprise deployments leverage these management capabilities to implement network segmentation strategies, enforce security policies at the network edge, and monitor traffic patterns for performance optimization and security analysis. The evolution toward software-defined networking has expanded switch capabilities to include programmable forwarding behaviours and centralized management through standardized management protocols such as NETCONF (IETF RFC 6241), RESTCONF (IETF RFC 8040).

4.5 Product architecture and components

Routers, modems intended for connection to the internet, and switches implement a multi-plane architecture based on the traditional separation of data, control, and management planes as described in networking standards such as ITU-T Y.2011 and further elaborated in IETF RFC 7426.

The data plane, also termed the forwarding plane, handles the high-speed processing of network traffic according to established policies and routing decisions. This plane typically employs specialized hardware including application-specific integrated circuits or network processors optimized for packet processing operations.

The control plane manages routing protocols, builds and maintains forwarding tables, and makes decisions about how packets should be forwarded through the network.

The management plane provides interfaces for product configuration, monitoring, and maintenance, including command-line interfaces, web-based management consoles, and programmatic APIs.

The physical architecture encompasses network interfaces supporting various media types and speeds, from gigabit Ethernet ports (IEEE 802.3 standards family) to high-speed fiber optic connections. Processing subsystems include central processing units for control and management functions, specialized network processors or ASICs for data plane operations, and memory subsystems comprising both volatile memory for operational data and non-volatile storage for firmware and configuration. Physical interfaces for local management include console ports, USB interfaces for configuration backup and restoration, as well as out-of-band management interfaces enabling remote administration even when primary network connections are unavailable.

The software architecture typically builds upon an embedded operating system, whether Linux-based, real-time operating system variants, or proprietary implementations. Network protocol stacks implement standard protocols for routing, switching, and various network services, while management software provides configuration interfaces, monitoring capabilities, and integration with network management systems. Security services operate across all architectural layers, implementing access controls at management interfaces, encryption for sensitive control plane communications, and packet filtering in the data plane. The firmware update mechanism represents a critical architectural component, requiring secure verification of update authenticity and integrity while maintaining service availability during update procedures.

5 Applicability model

5.1 General

The present document implements proportional security requirements through conditional applicability to address the fundamental challenge that routers, modems intended for connection to the internet, and switches operate across vastly different deployment contexts with correspondingly different threat exposures. These products serve environments ranging from residential homes with minimal physical security to critical infrastructure facilities with sophisticated threat actors, and from isolated local networks to internet-exposed management interfaces facing continuous automated attacks. Applying uniform security requirements across all these deployment scenarios would create an untenable situation where either high-risk deployments remain inadequately protected or low-risk implementations bear unnecessary complexity and cost that provides no meaningful security benefit.

The conditional applicability framework recognizes two distinct factors that influence security requirements: (i) inherent product capabilities and (ii) deployment scenarios. Product capabilities are technical features built into the device itself, such as whether management access is possible from the data plane, the presence of filtering mechanisms, or support for cryptographic protocols. Deployment scenarios describe how and where the product is used, including network architecture, physical security controls, and external protective measures that may limit access to the device.

The security measures necessary to protect a router with internet-accessible management interfaces differ from those required for a switch accessible only through a physical console port. Similarly, products with built-in access control capabilities require different considerations than those without such features. Furthermore, the same product may face different threat exposures depending on whether it is deployed with external protections (such as firewalls or network segmentation) or directly exposed to untrusted networks. By establishing conditions that correspond to both product capabilities and deployment scenarios, this framework ensures that each product implements security requirements proportionate to its actual risk profile and operational context.

Each requirement in clauses 6 and 7 either applies to all products within scope, addressing universal baseline threats that affect all deployments, or specifies conditions that determine when enhanced protections are necessary. Requirements without applicability conditions apply based on either the product's inherent capabilities (what the device can technically do) or common deployment scenarios (how the device is typically used), ensuring that additional security measures are implemented where the threat exposure justifies them.

5.2 Capability-based conditions

5.2.1 Introduction

The conditions defined in the following subsections are triggered by specific capabilities present in the product and determine which security requirements from clauses 6 and 7 apply. The conditions are organized into categories as follows:

(i) management access exposure conditions, which are determined by how the product's management interfaces can be accessed;

(ii) management operational model conditions, which are triggered by whether the product supports centralized or individual administration;

(iii) protocol and service conditions, which apply based on the network protocols and services the product implements.

A single product may meet multiple conditions simultaneously, with each applicable condition triggering its corresponding security requirements.

5.2.2 Management access exposure conditions

The following define conditions relative to the product's management interfaces:

[NE-1] Management interfaces are only accessible only through physical interfaces requiring direct physical presence at the product. This includes console ports, USB interfaces, serial connections, and any other management interface that cannot be accessed through network protocols. Network-based management protocols are either not implemented, disabled by design, or technically prevented from accepting network connections. This condition represents the minimum attack surface where remote exploitation of management interfaces is not possible.

[NE-2] Management interfaces are accessible through network protocols but only from products on the same network segment or broadcast domain. Access is restricted to the local network through technical controls such as binding to link-local addresses, Layer 2 of the OSI model isolation, or firewall rules that prevent routing from other network segments. Management protocols may include web interfaces or APIs, SSH, or other that respond only to connections originating from the same subnet or VLAN. Remote access from beyond the local network boundary is not possible without first establishing presence on the local segment.

[NE-3] Management interfaces are accessible from beyond the local network segment through routed connections but within defined organizational or network boundaries that inherently limit access scope. This includes management accessible through corporate WANs, site-to-site VPNs that connect specific locations, dedicated management VLANs that span multiple sites within an organization, or private MPLS networks. The defining characteristic is that management access requires traversing controlled network infrastructure where access is inherently limited to authorized network segments, even if additional authentication is not configured. External, public network-based access is not possible without first gaining access to these controlled network environments.

[NE-4] Management interfaces are accessible from the public network without network-based access restrictions. This condition applies when management interfaces can be reached from any internet location, whether through direct exposure or indirect mechanisms. Direct exposure occurs when management interfaces are bound to public IP addresses or made accessible by other means. Indirect exposure occurs when products establish outbound connections to network management platforms that accept connections from the internet, thereby creating a management path that originates from public networks. Under this condition, the product faces maximum exposure as neither geographic boundaries nor network segmentation limits potential management access attempts. Any entity with public network connectivity can potentially attempt to interact with the product's management interfaces, making this the highest risk configuration from a network exposure perspective.

5.2.3 Management operational model conditions

The following define conditions relative to the product administration:

[MM-1] The product is administered directly by end users or local IT staff without integration into network management systems.

[MM-2] The product is administered through network management systems by service providers, managed service providers, or organizational IT departments using protocols such as TR-069, TR-369, NETCONF, or vendor-specific management platforms.

5.2.4 Protocol and service conditions

The following define conditions based on the network protocols and services the product implements:

[PS-1] The product implements network management protocols that transmit data without mandatory encryption. This condition applies when the product supports any management protocol where authentication credentials, configuration commands, or system data can be transmitted in cleartext format.

[PS-2] The product implements network protocols that accept and process requests without requiring authentication. This condition applies to protocols that inherently process incoming requests based solely on network reachability without verification of the sender's identity or authorization.

[PS-3] The product implements protocols that disclose system information in response to unauthenticated network queries. This condition applies when the product responds to discovery, diagnostic, or information-gathering protocols without requiring prior authentication.

[PS-4] The product implements protocols with cryptographic mechanisms that do not meet current security standards. This condition applies when the product supports protocol versions using deprecated cryptographic algorithms, insufficient key lengths, or known-weak security mechanisms for backward compatibility.

[PS-5] The product implements protocols that establish trust relationships without cryptographic verification. This condition applies when the product participates in protocols that make security-relevant decisions based on unverified information from network peers.

5.3 Condition Assessment

5.3.1 General

The manufacturer shall assess and document the conditions from clause 5.2 applicable to its product.

NOTE: This Condition Assessment document shall be included in the Declaration of conformity [and in the product's technical documentation.]

The Condition Assessment identifies which conditions from **Error! Reference source not found.** apply to the product and therefore which requirements from clauses are applicable.

5.3.2 Content requirements

The Condition Assessment shall include:

- a) Product identification (Manufacturer, Product name, Product version).
- b) Firmware/software version assessed.

- c) Assessment of each condition defined in clause **Error! Reference source not found.** according to the following categories:
- a. Applicable - Default: the condition is met in the factory default configuration.
 - b. Applicable - Configurable: the condition can be met through configuration.
 - c. Not Applicable: the condition cannot be met by the product.
- d) Date of declaration.

5.3.3 Completeness

The manufacturer shall assess every condition defined in clause **Error! Reference source not found.** The assessment shall be documented in the Condition Assessment using the template provided in [Annex B \(8\)](#).

A condition assessed as "Applicable - Configurable" shall trigger the same requirements as a condition assessed as "Applicable - Default".

5.3.4 Maintenance of the Condition Assessment

The manufacturer shall revise the Condition Assessment when (i) a new version of firmware or software changes the applicability of any condition; and (ii) a hardware revision affects the presence of capabilities.

The Condition Assessment shall be maintained as part of the technical documentation.

5.4 Undeclared or misdeclared conditions

Products for which conditions apply that differ from those documented in the Condition Assessment shall be considered non-compliant with the present document. This non-compliance applies when conditions are applicable in any of the following scenarios: (i) default configuration creates the condition; (ii) documented configuration enables the condition; or (iii) undocumented procedures can establish the condition.

Two categories of violations shall result in non-compliance: (i) undeclared conditions, when conditions defined in clause 5.2 apply to the product but are not identified in the Condition Assessment; and (ii) misdeclared conditions, when the Condition Assessment incorrectly identifies which conditions from clause 5.2 apply to the product.

When firmware or software updates introduce features that make new conditions applicable or change which conditions apply, manufacturers shall revise the Condition Assessment before releasing the update. Updates that trigger different conditions from clause 5.2 require that the updated product meet all security requirements associated with those conditions.

Failure to update the Condition Assessment when applicable conditions change or releasing updates that modify which conditions apply without ensuring compliance with newly applicable requirements, shall constitute non-compliance with the present document. This obligation continues throughout the support lifecycle of the product, ensuring that security requirements remain aligned with the conditions that apply to the product.

6 Cybersecurity requirements

6.1 General

This clause establishes cybersecurity requirements for products within the scope of the present document. The requirements implement the essential cybersecurity requirements specified in Annex I Part I of Regulation (EU) 2024/2847.

Each requirement in this section either (i) specifies no applicability conditions, meaning the requirement applies to all products, or (ii) specifies applicability conditions, meaning the requirement applies only when the specified conditions from clause 5.2 are present in the product.

The presence of a capability in the product, whether enabled by default or through configuration, triggers all associated requirements. Manufacturers shall meet all applicable requirements based on the conditions present in their product as declared in the Condition Assessment specified in clause 5.4.

The requirements address the security properties necessary for routers, modems intended for connection to the internet, and switches operating in various deployment contexts and threat environments. The conditional applicability ensures proportionate security measures while maintaining essential security properties across all product implementations.

6.2 Secure by Design

6.2.1 General

This subclause addresses the CRA requirement that products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.

Routers, modems intended for the connection to the internet, and switches shall implement secure by design principles throughout their lifecycle by applying the horizontal requirements established in PT1 (General principles for cyber resilience), with additional considerations specific to their role in network connectivity and traffic management.

6.2.1.1 Input

- Applicable sections of PT1 (General principles for cyber resilience)
- Condition Assessment document as specified in clause 5.3

6.2.1.2 Requirements

[SBD-1-RQ-1-1] The product shall implement all applicable requirements from PT1 General principles for cyber resilience, including but not limited to: (i) risk assessment and treatment processes; (ii) security activities across all lifecycle stages; (iii) secure development and implementation; and (iv) secure production practices.

6.2.1.3 Output

- Evidence of PT1 (General principles for cyber resilience) compliance
- Risk assessment documentation addressing product-specific threats

6.2.1.4 Assessment criteria

- Applicable PT1 (General principles for cyber resilience) requirements are implemented and documented
- Risk treatment measures are proportionate to identified risks and consistent with declared conditions

NOTE: Assessment shall follow PT1 procedures, supplemented by validation of product-specific security considerations identified in this clause.

6.3 No known exploitable vulnerabilities

6.3.1.1 General

The manufacturer of routers, modems intended for the connection to the internet, and switches shall implement vulnerability identification and remediation processes throughout development and the whole lifetime, applying the horizontal requirements established in PT3 (Vulnerability Handling), with additional considerations specific to their role in network connectivity and traffic management.

6.3.1.2 Input

- List of applicable requirements from PT3
- Software Bill of Materials (SBOM)
- List of known exploitable vulnerabilities at the time of the assessment that may potentially affect product
- Vulnerability assessment results from development and testing
- Condition Assessment

6.3.1.3 Requirements

[NKV-1-RQ-1-01] The manufacturer shall implement all applicable requirements from PT3 Vulnerability Handling Requirements, ensuring that comprehensive vulnerability identification processes are applied before market release.

[NKV-1-RQ-1-02] The manufacturer shall implement all applicable requirements from PT3 Vulnerability Handling Requirements, ensuring that all identified vulnerabilities are remediated or, for low severity vulnerabilities identified after development has finished, documented including plans for addressing them.

[NKV-1-RQ-1-03] The manufacturer shall implement all applicable requirements from PT3 Vulnerability Handling Requirements, ensuring that third-party components are assessed against assessment of third-party components has been performed.

6.3.1.4 Output

- Vulnerability assessment report with remediation evidence
- Attestation that all vulnerabilities are identified after development has been finished, and that they are either removed or a plan for addressing them has been created

6.3.1.5 Assessment criteria

- Confirmation that vulnerability identification processes covered all product components
- Verification that all third-party components listed in the SBOM have been assessed
- Confirmation that all identified vulnerabilities are either remediated or plan for addressing them has been created
- Confirmation that the attestation of no known exploitable vulnerabilities is supported by testing evidence

6.4 Secure by Default Configuration

6.4.1 [DEFAULT] Secure by default configuration

6.4.1.1 General

This subclause addresses the CRA requirement that products with digital elements shall be made available on the market with a secure by default configuration. Routers, modems intended for connection to the internet, and switches represent critical network infrastructure that frequently serves as the primary security boundary between internal networks and external threats. These products must ship with security controls properly configured and enabled from initial deployment to protect against immediate exploitation attempts that often occur within minutes of network connection. The default configuration establishes the security baseline that many users, particularly in residential and small business deployments, will operate with minimal or no modification throughout the product lifecycle.

6.4.1.2 Input

- Product in factory default configuration state
- Network topology documentation for typical deployment scenarios
- Inventory of all network interfaces, services, and ports available on the product
- List of all security features and their default states
- Documentation of administrative interface access methods

6.4.1.3 Requirements

[DEFAULT-1-RQ-1-01] The product shall, in its factory default state, expose only those network interfaces and services accessible via network interfaces that are necessary for product setup. Network interfaces and services that are not essential for setup shall be disabled in the factory default configuration.

[DEFAULT-1-RQ-1-02] The product shall, in its factory default state, enable all available security features except those that would prevent product setup.

[DEFAULT-1-RQ-1-03] The product, in its factory default state, shall provide a secure default configuration where network interfaces and services are configured to accept connections only from appropriate network segments based on typical deployment topology.

[DEFAULT-1-RQ-1-04] The product, in its factory default state, shall ensure that administrative interfaces are configured with the principle of least privilege and require mandatory credential establishment before granting operational access.

[DEFAULT-1-RQ-1-05] The product shall not use universal or common factory default passwords. If default passwords are present, they shall be unique per product and generated using cryptographically secure random number generators following recognized standards.

[DEFAULT-1-RQ-1-06] The product shall, in its factory default state, have a secure configuration that ensures debugging and diagnostic interfaces are disabled.

[DEFAULT-1-RQ-1-07] The product shall, in its factory default state, provide a secure default configuration that ensures security audit event logging is enabled for authentication attempts, configuration changes, and system errors.

[DEFAULT-1-RQ-1-08] The product, in its factory default state, shall enforce a secure default configuration that requires mandatory change of critical security parameters, such as credentials for administrative interfaces, with minimum entropy sufficient to meet security risk assessment requirements.

6.4.1.4 Output

- Product configured with minimal exposed attack surface
- Evidence of unique per-device credentials or forced credential change mechanism
- Network service configuration limiting connections to appropriate segments
- Disabled state verification for all debug interfaces and diagnostic ports
- Security configuration baseline documentation
- User guidance on any security features requiring manual activation with justification for why they cannot be enabled by default

6.4.1.5 Assessment criteria

- Verification that only essential network interfaces and services are exposed in factory default state
- Confirmation that each exposed service is justified as necessary for setup or basic operation
- Validation that unique per-device credentials are implemented or mandatory credential change is enforced before operational access
- Verify that all required security features are enabled.
- Where applicable, verification that debugging interfaces are disabled or protected.
- Confirmation that audit logging captures authentication attempts, configuration changes, and system errors by default
- Validation that administrative interfaces enforce least privilege from initial configuration

6.4.2 [RESET] Factory reset

6.4.2.1 General

Factory reset mechanisms shall remove all data and user configurations while leaving the current running software and the firmware versions in place.

NOTE: The capability to "reset the product to its original state" as specified in the CRA is commonly referred to as "factory reset" in the networking industry. This standard uses the industry-standard term throughout.

6.4.2.2 Input

- Authenticated reset request through management interface or physical reset trigger through hardware mechanism
- Complete system state snapshot including all user configurations, stored data, and cryptographic materials
- Current operating system, application and firmware
- Audit log storage location that survives reset

6.4.2.3 Requirements

[RESET-1-RQ-1-01] The product shall provide a factory reset mechanism that removes all user configurations, data, and customizations.

[RESET-1-RQ-1-02] The product shall provide a factory reset mechanism that restores the product to its secure-by-default configuration.

[RESET-1-RQ-1-03] The product shall provide a factory reset mechanism that maintains the currently installed firmware version and all applied security updates.

NOTE: Reset mechanisms may include physical reset buttons, boot-time key sequences, remote command, or other methods appropriate to the deployment context. The chosen method shall balance reset needs with physical security risks.

[RESET-1-RQ-1-04] The product shall require authentication and authorization at the highest privilege level for any factory reset initiated through software, management interface, or remote command.

[RESET-1-RQ-1-05] Upon successful factory reset, the product shall not retain any information that could be used to reconstruct previous configuration or compromise user privacy.

[RESET-1-RQ-1-06] Applicable when condition [MM-2] or [NE-3] or [NE-4] is present: The product shall support verification that factory reset completed successfully by querying the specific user changeable parameters or configurations, and, the actual operated firmware version information of the product.

NOTE: The factory reset deletes also the user login credentials leading to the initial setup procedures as required with [DEFAULT-1-RQ-1-02].

6.4.2.4 Output

- Product restored to secure-by-default factory configuration as specified in 6.4.1
- All user data and configuration are erased and reasonably unrecoverable
- Current firmware version and security updates retained (not rolled back)
- Reset trigger source, timestamp, and completion status events shall be recorded to the secure storage
- Attestation of successful reset for remote verification (when applicable)
- Product ready for redeployment or secure disposal

6.4.2.5 Assessment criteria

- Verification that all categories of user data are irreversibly removed through forensic analysis
- Confirmation that product returns to exact factory default configuration documented in 6.4.1
- Validation that software-initiated reset requires highest privilege level authentication
- Testing that firmware version and security updates persist through reset process
- Confirmation that audit events persist in secure storage
- Testing that no previous configuration or user data can be reconstructed post-reset
- Validation of cryptographic attestation mechanism for remote reset verification (when applicable conditions are present)

6.5 Security Updates

6.5.1 [UPDATE] Update mechanisms

6.5.1.1 General

This clause establishes requirements for delivering and installing security remedies to address vulnerabilities throughout the product lifetime. Given that products can remain deployed for extended periods and may serve as critical infrastructure, robust update mechanisms are essential for maintaining security posture against evolving threats.

6.5.1.2 Input

- Vulnerability information requiring remediation
- Security update packages from manufacturer
- Current firmware version and configuration state
- Means to access the remedy and a way to apply it.
- User preferences and operational constraints

6.5.1.3 Requirements

[UPDATE-1-RQ-1-01] The product shall implement cryptographic verification of remedy to ensure authenticity and integrity. Verification mechanism should use current best practice but will also take into account constraints that the product may have.

NOTE: For the present context, XX cryptography covers the standards that are publicly endorsed, accepted and recommended. These standards can be obtained from the European Union Agency for Cybersecurity [ENISA] and are accepted among all EU member states.

[UPDATE-1-RQ-1-02] The product shall provide mechanisms to receive and install remedies throughout the defined support period, with cryptographic verification ensuring update integrity. These mechanisms shall ensure in the context of the following use cases, device capabilities and user configurations the secure update process: (i) the update mechanism is automated and activated by default, or (ii) the device update mechanism depends on user configurations and operates then automatically following the user configuration, or (iii) the device is centrally administrated, the device update is decided by the user, and the update mechanism is configured accordingly by the user.

NOTE: Device may check for remedies via the Internet, but other options shall be available to fit product characteristics and deployment scenarios. User shall be able to configure how this verification will be performed or prevent it completely.

[UPDATE-1-RQ-1-03] The product shall implement protection preventing unauthorized and unauthenticated installation of firmware.

[UPDATE-1-RQ-1-04] The product may have capabilities to notify users of available security updates through management interface indicators. If capability is present, it shall be configurable.

[UPDATE-1-RQ-1-05] The product should check for available remedies.

[UPDATE-1-RQ-1-06] The product shall generate audit events for all update activities including (i) remedy availability, (ii) download initiation and completion; and (iii) installation success or failure and store these events in persistent memory that survives the reset. Audit events shall retain the most recent 1024 entries in secure storage. Systems with demonstrable technical constraints preventing 1024 entries shall (i) document the non-zero constraint and maximum achievable capacity and (ii) implement the same first-in-first-out deletion policy when capacity is reached. Secure storage can be a hardware features or achieved by using software mechanisms documented by the manufacturer.

NOTE: Software mechanisms are features such as access control, protection from unauthorized modification and optionally confidentiality protection.

[UPDATE-1-RQ-1-07] The product shall implement resilient update mechanisms that maintain product operability when update processes are interrupted. Upon interruption of an update process the product shall either: (i) automatically rollback to the previously installed firmware version; (ii) resume the update process from the point of interruption upon restoration of normal conditions; or (iii) enter a recovery mode that enables restoration to a functional state through documented recovery procedures.

6.5.1.4 Output

- Successfully installed firmware
- Audit trail of update activities
- Rollback protection state confirmation
- Error messages and diagnostic information for failed update attempts

6.5.1.5 Assessment criteria

- Cryptographic signature validation using state-of-the-art algorithms
- Successful update installation
- Rollback prevention blocking all firmware downgrades
- Recovery from power loss and network interruption during updates
- Automatic updates setting shall be set as appropriate for the device and most common deployment scenarios
- Confirmation that audit events persist in secure storage
- All alternative update methods that the product supports are verified and functional

6.6 Access Control

6.6.1 [AUTH-1] Authentication

6.6.1.1 General

Authentication forms the fundamental security barrier preventing unauthorized modification of product. Given the critical role these products play in network connectivity and data routing, compromise of access controls can lead to widespread network disruption, data interception, or malicious traffic redirection. This subclause establishes requirements ensuring that only authorized users can access product management functions.

6.6.1.2 Input

- Management interfaces present on the product
- User credentials or authentication tokens
- Authentication attempt history and failed attempt counters
- External authentication system connectivity (if configured)
- Previous credential history for comparison
- Session context information (source IP, access time, interface type)
- Condition Assessment

6.6.1.3 Requirement

[AUTH-1-RQ-1-01] The product shall not permit operation with default credentials. Product shall implement one of the following approaches (i) generate unique credentials during secure production; or (ii) require mandatory credential establishment during initial setup before any operational access is granted.

[AUTH-1-RQ-1-02] The product shall ensure authentication credentials are transmitted exclusively through channels that provide state-of-the-art cryptographic protection. All authentication exchanges shall (i) use secure communication channels that provide confidentiality and integrity protection using state-of-the-art cryptography; and (ii) implement state-of-the-art mechanisms that prevent disclosure of secrets even over unencrypted channels.

[AUTH-1-RQ-1-03] The product shall store secrets using state-of-the-art methods. Secrets shall be processed through a state-of-the-art secure one-way function with appropriate salting. No secret shall be stored in plaintext or retrievable format.

[AUTH-1-RQ-1-04] The product shall enforce minimum credential entropy through either character complexity requirements or minimum length requirements. The password interface shall clearly communicate requirements and reject non-compliant passwords with appropriate user guidance.

[AUTH-1-RQ-1-05] The product shall implement basic brute force protection, including but not limited to one of the following mechanisms: (i) progressive delays between failed attempts starting at 1 second and doubling up to 120 seconds, and (ii) temporary account lockout after 10 failed attempts within a 5-minute window.

[AUTH-1-RQ-1-06] The product shall maintain authentication credential history preventing reuse of the previous 5 authentication credentials. Authentication credential changes shall be validated against this history before acceptance.

NOTE: Historical credentials are subject to the same storage security requirements as current credentials per [AUTH-1-RQ-1-03].

[AUTH-1-RQ-1-07] The product shall implement authentication controls that respond to anomalous behaviour by applying appropriate additional security measures. The product shall generate audit events for detected anomalies, and store these events in persistent memory that survives the reset. Audit events shall retain the most recent 1024 entries in secure storage. Systems with demonstrable technical constraints preventing 1024 entries shall (i) document the non-zero constraint and maximum achievable capacity and (ii) implement the same first-in-first-out deletion policy when capacity is reached. Secure storage can be a hardware features or achieved by using software mechanisms documented by the manufacturer.

NOTE: Anomalous behaviour may include access from new locations, unusual time periods, or access following configuration changes.

NOTE: Software mechanisms are features such as access control, protection from unauthorised modification and optionally confidentiality protection.

6.6.1.4 Output

- Authentication decision (success or failure)
- Session establishment tokens for successful authentication
- Audit event entries for all authentication attempts
- Account status indicators
- Brute force protection status (delay timer, lockout state)
- Anomaly detection alerts when suspicious patterns detected
- Integration status with external authentication systems (if applicable)
- Error messages with appropriate user guidance for rejected credentials

6.6.1.5 Assessment criteria

- Verification that default credentials cannot be used operationally
- Confirmation of cryptographic protection for credential transmission
- Validation of secure storage using one-way functions with salting
- Demonstration of password policy enforcement with clear user feedback
- Testing of brute force protection mechanisms (progressive delays or account lockout)
- Verification of credential history maintenance preventing reuse of previous 5 passwords
- Testing of external authentication system integration capabilities
- Validation of anomaly detection and corresponding audit event generation
- Confirmation that audit events persist in secure storage
- Testing that all authentication paths are covered

6.6.2 [AUTH-2] Authorization

6.6.2.1 General

This clause establishes requirements for controlling what authenticated users can do on product. While authentication verifies user identity, access control ensures users can only perform actions appropriate to their role. This is critical for product as different users require different privileges.

6.6.2.2 Input

- Successfully authenticated user identity (from subclause 6.6.1)
- Requested action or command
- User's assigned role(s) and privileges
- Resource being accessed (configuration, logs, interfaces)
- Current security context and session attributes
- Authorization policies and access control lists
- Condition Assessment

6.6.2.3 Requirements

[AUTH-2-RQ-1-01] The product shall implement a privilege separation mechanism that distinguishes at minimum between (i) read-only access (view configuration, statistics), and (ii) administrative access (modify configuration, system settings).

[AUTH-2-RQ-1-02] The product shall enforce access control on all management interfaces consistently, preventing privilege escalation through alternative interfaces.

[AUTH-2-RQ-1-03] The product shall implement command authorization that validates each command based on the authorized privilege level before execution.

[AUTH-2-RQ-1-04] The product shall not allow any user to perform actions beyond their authorized privilege level.

[AUTH-2-RQ-1-05] Applicable when condition [MM-2] is present: The product shall implement state-of-the-art

Access control mechanisms supporting (i) ability to create different user permissions, and (ii) granular permissions (for example, per-command or per-feature).

6.6.2.4 Output

- Access decision (permit/deny)
- Privilege level granted
- Audit event entry for access attempt
- Clear user feedback on permitted actions
- Command execution result (if authorized)

6.6.2.5 Assessment criteria

- Verification that privilege separation cannot be bypassed
- Testing of escalation prevention mechanisms
- Validation that all interfaces enforce consistent access control
- Confirmation of RBAC implementation (if applicable)
- Testing of external authorization integration (if applicable)
- Verification of command authorization and accounting

6.6.3 [AUTH-3] Authenticated session lifecycle

6.6.3.1 General

This subclause establishes requirements for managing the lifecycle of authenticated sessions, from establishment through termination, ensuring that the security context created through authentication (subclause 6.6.1) and authorization (subclause 6.6.2) is properly maintained throughout the user's interaction with the product. Session management forms a critical security control that preserves the integrity of authenticated access and prevents unauthorized actions through session compromise.

Given that products often remain accessible continuously and may be managed from various locations and interfaces simultaneously, robust session controls are essential to prevent unauthorized configuration changes that could compromise entire network segments. Session management vulnerabilities such as hijacking, fixation, or replay attacks can lead to complete product compromise even when strong authentication mechanisms are in place.

6.6.3.2 Input

- Successfully authenticated user identity
- Authorization context and privilege level
- Session initiation parameters (source IP, interface type, access protocol)
- User activity patterns and idle time measurements
- Condition Assessment

6.6.3.3 Requirements

These requirements are applicable when condition [NE-2] or [NE-3] or [NE-4] is present:

[AUTH-3-RQ-1-01] The product shall generate cryptographically secure session identifiers using state-of-the-art technology. Session identifiers shall be unique, non-predictable, and resistant to brute force attacks.

[AUTH-3-RQ-1-02] The product shall implement session timeout mechanisms with configurable idle timeout periods and appropriate default values.

[AUTH-3-RQ-1-03] The product shall invalidate sessions immediately upon (i) user-initiated logout; (ii) timeout expiration; (iii) authentication credential change; or (iv) administrative termination. Session invalidation shall securely remove all session data.

[AUTH-3-RQ-1-04] The product shall protect session identifiers by (i) transmitting them only over secure channels that provide confidentiality and integrity protection; (ii) implementing appropriate session token protection mechanisms for the interface type; and (iii) preventing session identifiers from appearing in audit events, logs, URLs, or error messages.

[AUTH-3-RQ-1-05] The product shall implement protection against session fixation (reuse of the session) by generating new session identifiers (i) upon successful authentication; (ii) before privilege elevation; (iii) when switching between security contexts; or (iv) when transitioning between untrusted and trusted network zones.

[AUTH-3-RQ-1-06] The product shall limit concurrent sessions to a configurable maximum per user account (default: 3 sessions) and shall provide (i) user visibility of all active sessions with source and timestamp information; and (ii) capability to selectively terminate sessions.

[AUTH-3-RQ-1-07] The product shall implement session security that detects privilege escalation attempts.

[AUTH-3-RQ-1-08] Applicable when condition [NE-3] or [NE-4] is present: The product shall generate audit events for session history including (i) complete session lifecycle events with timestamps; (ii) all source addresses and access methods; (iii) command summary or resource access patterns; (iv) privilege changes during session; and (v) abnormal termination reasons. Audit events shall retain the most recent 1024 entries in secure storage. Systems with demonstrable technical constraints preventing 1024 entries shall (i) document the non-zero constraint and maximum achievable capacity and (ii) implement the same first-in-first-out deletion policy when capacity is reached. Secure storage can be a hardware features or achieved by using software mechanisms documented by the manufacturer.

NOTE: Software mechanisms are features such as access control, protection from unauthorised modification and optionally confidentiality protection.

6.6.3.4 Output

- Cryptographically secure session identifier upon establishment
- Session termination confirmation with timestamp
- Idle timeout status and remaining time
- List of active sessions per user with source information
- Audit log entries for session events
- Anomaly detection alerts when triggered
- Session history records for forensic analysis

6.6.3.5 Assessment criteria

- Verification of session identifier entropy
- Testing of idle timeout enforcement (15 minutes) across all management interfaces
- Validation of session invalidation upon logout, timeout, credential change, anomalies, and admin termination
- Confirmation that session identifiers are transmitted only over secure channels and do not appear elsewhere
- Testing of session fixation prevention through ID regeneration at authentication and privilege elevation
- Verification of concurrent session limits (default 3) and user visibility/termination features
- Testing of adaptive security for unusual command patterns and privilege escalation detection
- Confirmation that audit events persist in secure storage
- Testing of audit event generation for session establishment, termination, and violations

6.6.4 [AUTH-4] Protocol access control

6.6.4.1 General

This subclause establishes requirements for administrative control over network protocols available on the product. Only authenticated and authorized users shall be permitted to enable, disable, or configure network protocols. Once enabled by an authorized user, protocols may operate according to their specifications, including those that inherently lack authentication mechanisms for protocol-level interactions.

6.6.4.2 Input

- Network protocol requests and interactions
- Protocol implementation inventory from Condition Assessment
- Authentication status from subclause 6.6.1
- Authorization status from subclause 6.6.2

6.6.4.3 Requirements

[AUTH-4-RQ-1-01] Applicable when any condition [PS-1] through [PS-5] is present: The product shall require authentication and authorization for any administrative action to enable, disable, or configure these protocols.

Administrative interfaces that control protocol behavior shall be protected regardless of whether the protocols themselves support authentication.

[AUTH-4-RQ-1-02] Applicable when condition [PS-1] is present: The product shall provide secure alternative protocols alongside cleartext management protocols and generate warnings when cleartext protocols are used.

[AUTH-4-RQ-1-03] Applicable when condition [PS-2] is present: The product shall implement rate limiting and source validation if possible for unauthenticated protocol requests to mitigate spoofing and injection attacks.

[AUTH-4-RQ-1-04] Applicable when condition [PS-3] is present: The product shall provide configuration options to disable or limit information disclosure through diagnostic protocols.

[AUTH-4-RQ-1-05] Applicable when condition [PS-4] is present: The product shall document deprecated cryptographic mechanisms and provide configuration options to disable weak protocol versions when operationally feasible.

[AUTH-4-RQ-1-06] Applicable when condition [PS-5] is present: The product shall implement additional validation mechanisms for trust establishment and provide audit logging for all trust relationship changes.

6.6.4.4 Output

- Administrative access decisions for protocol configuration requests
- Protocol enablement status showing which protocols are active/inactive
- Security warnings generated when cleartext protocols are used
- Rate limiting status and metrics for unauthenticated protocol requests
- Configuration state for diagnostic protocol restrictions
- Documentation of deprecated cryptographic mechanisms in use
- Audit logs for protocol configuration changes
- Audit logs for trust relationship establishment and changes
- User-visible indicators of protocol security status

6.6.4.5 Assessment criteria

- Verification that unauthenticated users cannot enable, disable, or configure protocol settings
- Confirmation that secure alternatives are available for each cleartext management protocol
- Testing that warnings are generated when cleartext protocols are activated or used
- Validation of rate limiting effectiveness against rapid unauthenticated protocol requests
- Testing that diagnostic protocols can be disabled or restricted through configuration
- Verification that information disclosure can be limited for each identified diagnostic protocol
- Review of documentation identifying all deprecated cryptographic mechanisms
- Testing that weak protocol versions can be disabled when configuration option is provided
- Validation of additional trust establishment mechanisms beyond basic protocol operation
- Verification that audit logs capture all trust relationship changes with sufficient detail
- Testing that all protocol configuration changes require and verify appropriate authorization levels
- Confirmation that protocol security controls do not prevent legitimate protocol operation once enabled

6.7 Data Protection

6.7.1.1 General

This subclause establishes requirements for protecting data confidentiality, integrity, and minimization throughout the product lifecycle. Data protection encompasses three fundamental principles: (i) confidentiality ensures that sensitive information remains accessible only to authorized entities; (ii) integrity guarantees that data cannot be modified without authorization; and (iii) data minimization limits collection and retention to what is necessary for intended functions. The implementation of these principles must address all data types processed by the product, with protection measures appropriate to operational requirements and threat exposure. Security controls prevent both passive interception and active manipulation of data while maintaining product functionality and performance requirements.

6.7.1.2 Input

- Inventory of all data types processed, stored, and transmitted by the product

- 1214 • Data flow diagrams showing movement between components and interfaces
- 1215 • Cryptographic capabilities and available encryption mechanisms
- 1216 • Configuration and operational data storage locations
- 1217 • Network protocol specifications and their security features

1218 6.7.1.3 Requirements

1219 [DATA-1-RQ-1-1] The product shall implement comprehensive data protection measures ensuring all sensitive data
1220 including passwords, cryptographic keys, and user credentials are encrypted at rest using state-of-the-art cryptographic
1221 algorithms with appropriate key management.

1222 [DATA-1-RQ-1-2] The product shall implement comprehensive data protection measures ensuring all management
1223 communications and control plane traffic employ encrypted channels providing both confidentiality and integrity
1224 protection through state-of-the-art cryptography.

1225 [DATA-1-RQ-1-3] The product shall implement comprehensive data protection measures ensuring configuration files
1226 and firmware images are protected against unauthorized modification.

1227 [DATA-1-RQ-1-4] The product shall implement comprehensive data protection measures ensuring the product
1228 processes and retains only the minimum data necessary for its intended routing, switching, or modem functions, with
1229 configurable options to disable collection of non-essential diagnostic or telemetry data.

1230 [DATA-1-RQ-1-5] The product shall implement comprehensive data protection measures ensuring any corruption or
1231 unauthorized modification of protected data generates immediate audit events and triggers appropriate recovery
1232 procedures.

1233 6.7.1.4 Output

- 1234 • Cryptographic implementation documentation specifying algorithms and key lengths
- 1235 • Data classification matrix identifying all sensitive data and protection methods
- 1236 • Audit log entries for data integrity violations and unauthorized access attempts
- 1237 • Configuration options for data collection and retention policies

1238 6.7.1.5 Assessment criteria

- 1239 • Verification that all identified sensitive data types are encrypted at rest using state-of-the-art algorithms
- 1240 • Confirmation that management communications and control plane traffic use encrypted channels with both
1241 confidentiality and integrity protection
- 1242 • Testing of recovery procedures following data integrity violations
- 1243 • Verification that key management procedures prevent key exposure or unauthorized access

1244 6.8 Availability and Resilience

1245 6.8.1.1 General

1246 This subclause establishes requirements for maintaining essential functions and preventing service disruptions,
1247 including protection against denial-of-service attacks. Availability and resilience encompass two core objectives: (i)
1248 maintaining operational continuity of essential functions during and after security incidents; and (ii) preventing the
1249 product from being used as a vector to disrupt other networks or services. The implementation of these objectives must
1250 ensure that products can detect, withstand, and recover from attacks while preserving core network operations.

1251 6.8.1.2 Input

- 1252 • Product operational baseline and normal performance parameters
- 1253 • Common denial-of-service attack patterns
- 1254 • Recovery mechanisms and procedures
- 1255 • Condition Assessment

6.8.1.3 Requirements

[AVAIL-1-RQ-1-1] The product shall maintain resilience against denial-of-service attacks and ensure restoration of normal operation after attack cessation.

[AVAIL-1-RQ-1-2] The product shall automatically recover to normal operational state when denial-of-service conditions cease, without requiring manual intervention for basic functionality restoration.

[AVAIL-1-RQ-1-3] The product shall not rely only on automatic reset as the protection mechanism for ensuring the availability of essential and basic functions.

[AVAIL-1-RQ-1-4] The product shall generate audit events when denial-of-service attack indicators are (i) detected and mitigation actions taken; and (ii) when the attack ceases and normal operation is restored. Audit events shall retain the most recent 1024 entries in secure storage. Systems with demonstrable technical constraints preventing 1024 entries shall (i) document the non-zero constraint and maximum achievable capacity and (ii) implement the same first-in-first-out deletion policy when capacity is reached. Secure storage can be a hardware features or achieved by using software mechanisms documented by the manufacturer.

NOTE: Software mechanisms are features such as access control, protection from unauthorised modification and optionally confidentiality protection.

6.8.1.4 Output

- Operational status during and after denial-of-service conditions
- Event logs documenting attack detection and recovery
- Confirmation of service restoration

6.8.1.5 Assessment criteria

- Verification that the product recovers normal operation after denial-of-service attacks

6.9 Attack Surface and Mitigation

6.9.1 [INTEGRITY] System integrity and boot process

6.9.1.1 General

This section establishes requirements for ensuring the integrity of product throughout their operational lifecycle, from initial power-on through runtime operation. System integrity forms the foundational trust anchor upon which all other security controls depend. A compromised boot process or runtime environment can subvert authentication, bypass access controls, and provide persistent unauthorized access that survives reboots and firmware updates.

The boot process represents a critical attack surface where malicious actors attempt to install persistent implants, bypass security controls, or extract cryptographic materials. Given that product often operate autonomously for extended periods and control critical network functions, ensuring boot integrity and maintaining runtime security are essential for preventing sophisticated attacks that could compromise entire network segments.

6.9.1.2 Input

- Firmware images and boot components
- Cryptographic keys and certificates for verification
- Boot configuration parameters
- Recovery mode triggers
- Previous boot state and security events

6.9.1.3 Requirements

[INTEGRITY-1-RQ-1-01] The product shall implement cryptographic verification of boot components using state-of-the-art cryptographic methods.

[INTEGRITY-1-RQ-1-02] The product shall establish a secure boot chain where (i) each stage verifies the next stage before transferring control; (ii) the initial bootloader is immutable or hardware-protected; (iii) verification failures halt the boot process; and (iv) only verified code can execute during normal boot.

[INTEGRITY-1-RQ-1-03] For a physical product, the product shall detect and respond to secure boot bypass attempts including (i) physical jumper or pin manipulation; (ii) boot product substitution; (iii) memory modification attacks; and (iv) fault injection attempts

[INTEGRITY-1-RQ-1-04] The product shall maintain a secure audit log of all boot events including (i) boot stage progression with timestamps; (ii) verification, either success or failure, for each component; (iii) recovery mode activation; and (iv) detected bypass attempts. These audit events shall retain the most recent 1024 entries in secure storage, with the oldest entry deleted when a new entry would exceed this limit. Systems with demonstrable technical constraints preventing 1024 entries shall (i) document the non-zero constraint and maximum achievable capacity and (ii) implement the same first-in-first-out deletion policy when capacity is reached. Secure storage can be a hardware feature or achieved by using software mechanisms documented by the manufacturer.

NOTE: Software mechanisms are features such as access control, protection from unauthorised modification and optionally confidentiality protection.

[INTEGRITY-1-RQ-1-05] The product shall protect recovery and maintenance modes if present by implementing authentication and authorization before granting access.

[INTEGRITY-1-RQ-1-07] The product shall protect recovery and maintenance modes if present by creating an audit event for all recovery mode access.

[INTEGRITY-1-RQ-1-08] The product shall implement recovery mechanisms.

NOTE: For example automated rollback to known-good states; self-healing capabilities for detected corruptions; redundant boot paths with automatic failover; or integrity verification of backup systems.

6.9.1.4 Output

- Boot status with detailed stage information
- Integrity verification results for all components
- Audit event for boot and runtime events
- Recovery mode activation records
- Runtime anomaly alerts and incident reports
- Compliance state attestations

6.9.1.5 Assessment criteria

- Verification of cryptographic validation during boot
- Testing of boot chain integrity with software component substitution
- Validation of bypass attempt detection mechanisms
- Assessment of recovery mode security controls
- Runtime monitoring effectiveness through fault injection
- Resilience testing under active attack scenarios

6.9.2 [PACKET] Default packet disposition

6.9.2.1 General

Routers, modems intended for connection to the internet, and switches implement packet processing through various architectural approaches optimized for their intended deployment scenarios. While validation covers standardized protocols and expected traffic patterns, the theoretical space of all possible packet constructions remains unbounded. Packets with unexpected protocol combinations, unusual encapsulations with non-standard extension headers, or deeply nested tunnelling may fall outside validated processing paths. When packet processing components encounter formats

for which no validated processing path exists, the product requires deterministic behaviour to maintain security and availability. The absence of explicit handling procedures for such packets could otherwise result in undefined states, memory corruption, or unpredictable behaviour.

Products shall implement deterministic behaviour when encountering packets outside their processing domain rather than attempting best-effort processing that may trigger undefined behaviour in hardware acceleration engines or software protocol stacks.

This requirement applies to all products within scope regardless of deployment context, as the inability to safely handle unexpected packets represents a fundamental security vulnerability that can be exploited from any network position. The requirement establishes that products shall default to dropping packets rather than forwarding or processing them when the correct action cannot be determined with certainty.

6.9.2.2 Input

- Incoming packets from any network interface
- Protocol specifications for supported packet types
- Configured forwarding and filtering rules
- Current protocol state machines

6.9.2.3 Requirements

[PACKET-1-RQ-1-01] The product shall drop any packet for which it cannot determine the appropriate processing action based on implemented protocol handlers, forwarding rules, or state machines. This includes (i) packets with unrecognized protocol identifiers or type fields; (ii) packets with invalid or unexpected encapsulation combinations; (iii) packets that would require processing beyond the product's implemented protocol stack depth; (iv) packets with header field values outside the ranges specified in relevant protocol standards; (v) packets that cannot be matched to existing connection state for stateful protocols; and (vi) any packet that would trigger undefined behaviour in product.

[PACKET-1-RQ-1-02] The product shall not attempt partial processing, best-effort forwarding, or fallback handling for packets that cannot be fully validated against implemented protocol specifications. When packet processing uncertainty exists at any protocol layer, the entire packet shall be dropped rather than processed at other layers.

6.9.2.4 Output

- Dropped packets that cannot be safely processed
- No undefined behaviour or system instability from malformed packets

6.9.2.5 Assessment criteria

- Verification that the product drops packets for which no valid processing path exists
- Confirmation that the product maintains stable operation when subjected to continuous streams of packets requiring drop decisions
- Confirmation that packet drop behaviour occurs consistently and deterministically based on packet characteristics
- Confirmation that packet drop decisions leave no residual state that could affect processing of subsequent valid packets

6.9.3 [EXPOSURE] Interface and service exposure minimization

6.9.3.1 General

This subclause establishes requirements for minimizing the attack surface by limiting exposed interfaces and services. Products shall implement the principle of least functionality, exposing only those interfaces and services necessary for their intended operation. Given that each exposed interface represents a potential attack vector, systematic reduction of unnecessary exposure directly reduces the probability of successful exploitation.

6.9.3.2 Input

- Inventory of all network interfaces and services
- Operational requirements for the deployment scenario
- Condition Assessment

6.9.3.3 Requirements

[EXPOSURE-1-RQ-1-01] The product shall disable all interfaces and services that are not essential for the product's intended function in its default configuration, including but not limited to: (i) debug interfaces such as JTAG, UART, and SWD unless physically secured; (ii) unused network protocols and services; (iii) test modes and diagnostic functions not required for normal operation; (iv) legacy protocols maintained only for backward compatibility when not actively required; and (v) any management interfaces beyond those explicitly documented for user access.

[EXPOSURE-1-RQ-1-02] The product shall provide capability to selectively enable or disable individual services and interfaces through configuration, with clear documentation of the security implications of enabling each service.

[EXPOSURE-1-RQ-1-03] Applicable when condition [NE-4] is present: The product shall implement rate limiting and connection throttling on all exposed network interfaces to mitigate resource exhaustion attacks, including: (i) maximum concurrent connections per source; (ii) connection establishment rate limits; (iii) protocol-specific rate limiting for management protocols; and (iv) automatic blocking of sources exceeding defined thresholds.

6.9.3.4 Output

- Minimized attack surface with only essential interfaces and services active in default configuration
- Configuration interface providing granular control over individual services and interfaces
- Documentation clearly identifying which interfaces/services are enabled vs disabled
- Security impact documentation for each configurable service

6.9.3.5 Assessment criteria

- Verification that all non-essential interfaces listed in requirement (debug interfaces, unused protocols, test modes, legacy protocols, undocumented management interfaces) are disabled by default
- Confirmation that disabled interfaces cannot be accessed or enumerated through any means without explicit enablement
- Testing that debug interfaces (JTAG, UART, SWD) when present are either physically secured or completely disabled at hardware/firmware level
- Validation of configuration mechanism allowing individual enable/disable control for each service and interface
- Verification that security documentation clearly describes risks of enabling each optional service

6.10 Monitoring and Logging

6.10.1.1 General

This subclause establishes requirements for recording and monitoring security-relevant activities to enable incident detection, forensic analysis, and compliance verification. Monitoring and logging captures authentication attempts, configuration changes, system events, and administrative actions that affect product security posture. Event data is protected against unauthorized modification or deletion, with configurable retention periods and logging scope based on operational requirements and resource constraints.

6.10.1.2 Input

- Authentication events from access control subsystem
- Authorization events from access control subsystem

6.10.1.3 Requirements

[LOG-1-RQ-1-01] The product shall generate audit events for failed authentication attempts.

[LOG-1-RQ-1-02] The product shall generate audit events for all authentication activities including (i) successful authentication; (ii) account lockout triggers and releases; and (iii) authentication credential change attempts (successful and failed).

[LOG-1-RQ-1-03] The product shall generate audit events for all session lifecycle activities including (i) session establishment with source details; (ii) session termination with reason; (iii) failed session validation attempts; and (iv) concurrent session limit violations.

1444 [LOG-1-RQ-2-02] The product shall implement command authorization that creates audit event of unauthorized
1445 commands.

1446 [LOG-1-RQ-4-01] The product shall allow at least 30 days of log retention with rotation in place. The product shall
1447 allow at least 30 days of log retention with rotation in place. Systems with demonstrable technical constraints
1448 preventing 30 days of retention shall (i) document the constraint and maximum achievable non-zero retention period,
1449 and (ii) implement mandatory rotation to maximize retention within available storage.

1450 6.10.1.4 Output

- 1451 • Timestamped audit log entries for all security events

1452 6.10.1.5 Assessment criteria

- 1453 • Verification that all security events generate appropriate audit events

1454

1455 6.11 Data Management

1456 6.11.1 [TRANSFER] Secure data export and transfer

1457 6.11.1.1 General

1458 This subclause addresses the requirement for secure data portability between products, enabling users to migrate
1459 configurations, operational data, and system state without compromising security. Configuration files for routers,
1460 modems intended for connection to the internet, and switches contain sensitive information including credentials,
1461 cryptographic keys, network topology details, and security policies that require protection during export and transfer.

1462 The transfer mechanism ensures data exports are encrypted to maintain confidentiality even if transfer media is
1463 compromised or intercepted, while preventing unauthorized modification that could compromise the target system upon
1464 import.

1465 6.11.1.2 Input

- 1466 • User request for data export initiated through management interface

1467 6.11.1.3 Requirements

1468 [TRANSFER-1-RQ-1-01] The product shall support secure data export, allowing users to transfer the exported data.

1469 [TRANSFER-1-RQ-1-02] The product shall support secure data import, allowing users to import data in the product.

1470 6.11.1.4 Output

- 1471 • Encrypted export file containing requested configuration and data
- 1472 • Configuration format documentation/schema for external validation

1473 6.11.1.5 Assessment criteria

- 1474 • Confirmation that exported configuration can be successfully imported
- 1475 • Verification of cryptographic signature validation for integrity checking
- 1476 • Testing that third-party tools can parse and analyze the configuration format

1477 7 Vulnerability Handling Requirements

1478 7.1 General

1479 This clause establishes cybersecurity requirements for products within the scope of the present document. The
1480 requirements implement the essential cybersecurity requirements specified in Annex I Part II of Regulation (EU)
1481 2024/2847.

The requirements address the vulnerability handling processes necessary for routers, modems intended for the connection to the internet, and switches operating in various deployment contexts and threat environments. These requirements apply to all products within scope, ensuring consistent security maintenance capabilities throughout the product support period while accounting for the operational constraints typical of network infrastructure.

[Requirements here are to be developed with reference to PT1 and PT3. This section shall focus on network equipment-specific considerations while referencing the horizontal standards for baseline requirements.]

7.2 Vulnerability identification and documentation

7.2.1 General

This subclause addresses the CRA requirement that manufacturers of products with digital elements shall identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products.

7.2.1.1 Input

7.2.1.2 Requirements

7.2.1.3 Output

7.2.1.4 Assessment criteria

7.3 Vulnerability Remediation

7.3.1 General

This subclause addresses the CRA requirement that manufacturers of products with digital elements shall in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates; where technically feasible, new security updates shall be provided separately from functionality updates;

7.3.1.1 Input

7.3.1.2 Requirements

7.3.1.3 Output

7.3.1.4 Assessment criteria

7.4 Security testing and review

7.4.1 General

This subclause addresses the CRA requirement that manufacturers of products with digital elements shall apply effective and regular tests and reviews of the security of the product with digital elements.

1515 7.4.1.1 Input

1516 7.4.1.2 Requirements

1517 7.4.1.3 Output

1518 7.4.1.4 Assessment criteria

1519

1520 7.5 Vulnerability disclosure

1521 7.5.1 General

1522 This subclause addresses the CRA requirement that manufacturers of products with digital elements shall once a
1523 security update has been made available, share and publicly disclose information about fixed vulnerabilities, including a
1524 description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the
1525 impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the
1526 vulnerabilities; in duly justified cases, where manufacturers consider the security risks of publication to outweigh the
1527 security benefits, they may delay making public information regarding a fixed vulnerability until after users have been
1528 given the possibility to apply the relevant patch.

1529 7.5.1.1 Input

1530 7.5.1.2 Requirements

1531 7.5.1.3 Output

1532 7.5.1.4 Assessment criteria

1533

1534 7.6 Coordinated vulnerability disclosure policy

1535 7.6.1 General

1536 This subclause addresses the CRA requirement that manufacturers of products with digital elements shall put in place
1537 and enforce a policy on coordinated vulnerability disclosure.

1538 7.6.1.1 Input

1539 7.6.1.2 Requirements

1540 7.6.1.3 Output

1541 7.6.1.4 Assessment criteria

1542

1543 7.7 Vulnerability reporting mechanisms

1544 7.7.1 General

1545 This subclause addresses the CRA requirement that manufacturers of products with digital elements shall take measures
1546 to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in
1547 third-party components contained in that product, including by providing a contact address for the reporting of the
1548 vulnerabilities discovered in the product with digital elements.

1549 7.7.1.1 Input

1550 7.7.1.2 Requirements

1551 7.7.1.3 Output

1552 7.7.1.4 Assessment criteria

1553

1554

1555 7.8 Update distribution

1556 7.8.1 General

1557 This subclause addresses the CRA requirement that manufacturers of products with digital elements shall provide for
1558 mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or
1559 mitigated in a timely manner and, where applicable for security updates, in an automatic manner.

1560

1561 7.8.1.1 Input

1562 7.8.1.2 Requirements

1563 7.8.1.3 Output

1564 7.8.1.4 Assessment criteria

1565

1566

1567

1568 7.9 Security advisory and user guidance

1569 7.9.1 General

1570 This subclause addresses the CRA requirement that manufacturers of products with digital elements shall ensure that,
1571 where security updates are available to address identified security issues, they are disseminated without delay and,
1572 unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital
1573 elements, free of charge, accompanied by advisory messages providing users with the relevant information, including
1574 on potential action to be taken.

1575

1576 7.9.1.1 Input

1577 7.9.1.2 Requirements

1578 7.9.1.3 Output

1579 7.9.1.4 Assessment criteria

1580

Annex A (informative): Relationship between the present document and the requirements of EU Regulation [Reference numbers of legislation]

The present document has been prepared in response to the Commission's standardisation request C(2025)618 [i.3] to provide, in additions to its other uses, one voluntary means of conforming to the essential requirements of Regulation (EU) 2024/2847 [i.2] known as the Cyber Resilience Act (CRA).

Once the present document is cited in the Official Journal of the European Union under Regulation (EU) 2024/2847 [i.2], conformance with the normative clauses of the present document given in the tables in Annex A confers, to products with digital elements in the scope of the present document, a presumption of conformity with the corresponding essential requirements of that Regulation and associated EFTA regulations.

**Table A.1: Relationship between the present document and
the requirements of Regulation NNN/YYYY**

Harmonised Standard ETSI EN <NUMBER>					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
1	Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.	Annex I, Part I, (1)	Clauses 5 and 6.2 implement a risk-based approach through scaled requirements	U	-
2	Products with digital elements shall be made available on the market without known exploitable vulnerabilities.	Annex I, Part I, (2)(a)	Clause 6.3		
3	Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state.	Annex I, Part I, (2)(b)	Clause 6.4		
4	Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed	Annex I, Part I, (2)(c)	Clause 6.5		

Harmonised Standard ETSI EN <NUMBER>					
Requirement			Requirement Conditionality		
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
	within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them.				
5	Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access	Annex I, Part I, (2)(d)	Clause 6.6		
6	Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state-of-the-art mechanisms, and by using other technical means.	Annex I, Part I, (2)(e)	Clause 6.7		
7	Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions.	Annex I, Part I, (2)(f)	Clause 6.7		
8	Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital	Annex I, Part I, (2)(g)	Clause 6.7		

Harmonised Standard ETSI EN <NUMBER>					
Requirement			Requirement Conditionality		
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
	elements (data minimisation).				
9	Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks.	Annex I, Part I, (2)(h)	Clause 6.8		
10	Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks.	Annex I, Part I, (2)(i)	Clause 6.8		
11	Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces.	Annex I, Part I, (2)(j)	Clause 6.9		
12	Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques.	Annex I, Part I, (2)(k)	Clause 6.9		
13	Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user.	Annex I, Part I, (2)(l)	Clause 6.10		
14	Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.	Annex I, Part I, (2)(m)	Clauses 6.4.2 and 6.11		
...					

1594

1595 **Key to columns:**1596 **Requirement:**1597 **No** A unique identifier for one row of the table which may be used to identify a requirement.1598 **Description** A textual reference to the requirement.1599 **Requirements of Regulation**

1600 Identification of article(s) defining the requirement in the Regulation.

1601 **Clause(s) of the present document**1602 Identification of clause(s) defining the requirement in the present document unless another
1603 document is referenced explicitly.1604 **Requirement Conditionality:**1605 **U/C** Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the
1606 manufacturer's claimed functionality of the equipment (C).1607 **Condition** Explains the conditions when the requirement is or is not applicable for a requirement which is
1608 classified "conditional".1609 Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list
1610 published in the Official Journal of the European Union. Users of the present document should consult frequently the
1611 latest list published in the Official Journal of the European Union.

1612 Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

1613

1614

8 Annex B (normative): Condition Assessment

This annex provides the normative template for the Condition Assessment required by clause **Error! Reference source not found.** Manufacturers shall use this template to document which conditions defined in clause 5.2 apply to their product, thereby determining which security requirements from clauses 6 and 7 are applicable.

The Condition Assessment forms part of the technical documentation and shall be maintained throughout the product lifecycle as specified in clause 5.3.4.

8.1 Instructions for completion

8.1.1 Assessment categories

For each condition listed in the template, the manufacturer shall select one of the following assessment categories:

- a) Applicable - Default: The condition is present in the factory default configuration without requiring any configuration changes by the user.
- b) Applicable - Configurable: The condition is not present in the factory default configuration but can be enabled through user configuration, documented features, or administrative commands.
- c) Not Applicable: The condition cannot be met by the product under any configuration or operational mode. The product lacks the technical capability to create this condition.

8.1.2 Assessment principles

The assessment shall follow these principles:

- If a capability exists in the product, even if disabled by default, it shall be declared as "Applicable - Configurable" at minimum.
- Undocumented or hidden capabilities, if present, must be declared. Discovery of undeclared capabilities constitutes non-compliance per clause 5.4.
- When a product can operate in multiple modes, assess capabilities across all operational modes.
- For products with modular hardware or software features, assess based on all possible configurations available to end users.
- If uncertainty exists about whether a condition applies, select the more restrictive assessment that triggers additional security requirements.

8.2 Condition Assessment Template

TODO.

9 Annex C (informative): Product deployment contexts and use cases

9.1 Use cases and deployment scenarios

9.1.1 Residential deployments

Residential network infrastructure typically includes a modem intended for connection to the internet, which incorporates wireless access point functionality, serving households with multiple connected products including computers, smartphones, smart home appliances, and entertainment systems. These modems intended for connection to the internet connect directly to internet service providers through cable, DSL, or fiber connections, operating with minimal technical oversight from users who expect plug-and-play functionality with default configurations. The network boundary between trusted products connected to the private network and the public network relies entirely on the security controls implemented by these products, as residential users rarely deploy additional security layers. Traffic patterns include streaming media, web browsing, remote work connections, online gaming, and increasingly, smart home product communications with cloud services, creating diverse security requirements within a single deployment.

9.1.2 Small and medium enterprise deployments

Small and medium enterprises deploy network infrastructure supporting business operations including point-of-sale systems, employee workstations, guest wireless networks, and connections to cloud-based business applications. These environments typically feature managed switches for network segmentation between employee and customer networks, business-grade routers with virtual private network capabilities for remote worker connections, and often, dedicated security appliances or router-integrated security features for threat protection. While some technical expertise may be available through internal IT staff or managed service providers, resource constraints often limit the implementation of comprehensive security monitoring and rapid response capabilities. Business continuity requirements demand high availability, though redundancy implementations vary significantly based on enterprise resources and risk tolerance.

9.1.3 Enterprise and data center deployments

Large enterprise deployments utilize hierarchical network architectures with core, distribution, and access layer switches managing thousands of endpoints across multiple physical locations. High-performance routers handle inter-site connectivity, internet edge routing, and complex traffic engineering requirements while implementing sophisticated security policies and quality of service guarantees. These environments feature redundant paths, automated failover mechanisms, and extensive monitoring infrastructure to maintain service availability for business-critical applications. Network segmentation enforces security boundaries between departments, applications, and user populations, with dedicated security teams managing firewall rules, intrusion detection systems, and incident response procedures. The infrastructure supports diverse traffic types including real-time communications, database replication, backup transfers, and user application traffic, each with specific performance and security requirements.

9.1.4 Critical infrastructure and industrial deployments

Critical infrastructure sectors including energy, transportation, healthcare, and telecommunications deploy network products in environments where availability and integrity directly impact public safety and essential services. These deployments often involve specialized industrial protocols, real-time control system communications, and strict segregation between operational technology and information technology networks. Routers and switches in these environments must maintain deterministic performance characteristics while implementing defense-in-depth security architectures that assume persistent adversarial presence. Regulatory compliance requirements mandate specific security controls, incident reporting procedures, and recovery time objectives that influence product selection and configuration. The extended operational lifecycles common in industrial settings, often spanning decades, create unique challenges for vulnerability management and security updates that must not disrupt continuous operations.

9.1.5 Service provider and carrier networks

Internet service providers and telecommunications carriers deploy carrier-grade routing and switching infrastructure handling millions of subscriber connections. These deployments implement complex routing protocols including BGP for internet backbone connectivity as well as segment routing for network programmability. The infrastructure must simultaneously support residential broadband, enterprise services, mobile backhaul, and content delivery networks while maintaining strict service level agreements. Security requirements encompass both protecting the provider's

infrastructure from attacks and implementing lawful intercept capabilities, distributed denial of service mitigation, and subscriber isolation. The scale of these deployments necessitates automated configuration management, real-time telemetry collection, and respond to security incidents across vast network areas.

9.1.6 Cloud and virtualized environments

Cloud service providers and enterprises implementing private clouds increasingly deploy virtual routers and switches as software-defined networking components within virtualized infrastructure. These virtual network functions operate on commodity hardware, providing programmable network services that can be dynamically instantiated, scaled, and reconfigured through orchestration platforms. The abstraction of network functions from physical hardware enables rapid service deployment and infrastructure agility but introduces new security considerations around hypervisor vulnerabilities, east-west traffic visibility, and control plane security. Multi-tenant environments require strict isolation between customer networks while enabling controlled inter-tenant connectivity for partner integrations. The dynamic nature of cloud environments, with workloads continuously migrating and scaling, demands security controls that can adapt to changing network topologies while maintaining consistent policy enforcement.

9.2 Product essential functions

Routers, modem intended for connection to the internet and switches perform functions that enable digital communications across interconnected systems. These essential functions shall remain operational and secure throughout the product lifecycle to maintain network integrity and availability.

9.2.1 Network traffic forwarding and routing

The fundamental function involves receiving network packets, making forwarding decisions based on destination addresses and routing policies, and transmitting packets toward their destinations. This includes maintaining routing tables, processing routing protocol updates, calculating optimal paths, and handling traffic at wire speed without introducing unacceptable latency or packet loss.

9.2.2 Network protocol implementation

Routers, modem intended for connection to the internet and switches process and forward traffic using standardized communication protocols across multiple network layers. These implementations handle protocol encoding and decoding, state management, and error handling. The products coordinate between different protocol layers while maintaining interoperability with other network products from various vendors.

9.2.3 Access control and security policy enforcement

Access control and security policy enforcement constitute essential functions that govern administrative access to products and regulate the flow of network traffic according to defined security policies. These functions establish the framework that determines which entities can modify product configuration and how network traffic is permitted or restricted based on security requirements.

For administrative access control, routers, modems intended for connection to the internet, and switches implement authentication mechanisms that verify the identity of users attempting to access management functions. Following authentication, these products enforce authorization policies that determine which commands and configuration changes each authenticated user can execute based on their assigned privileges. This includes maintaining role-based access controls that separate read-only monitoring functions from configuration modification capabilities, ensuring that users can only perform actions appropriate to their administrative role. The products maintain these access control decisions across sessions and preserve them through system restarts by storing authentication credentials and authorization policies in protected non-volatile memory.

Security policy enforcement extends beyond administrative access to encompass the control of network traffic flows. These products implement access control lists and filtering rules that determine which packets are permitted to traverse network boundaries based on source and destination addresses, protocols, and port numbers. They enforce network segmentation policies that maintain isolation between different security zones, preventing unauthorized communication between network segments with different trust levels. For products operating at network boundaries, this function includes enforcing policies that distinguish between traffic originating from trusted internal networks and untrusted external sources, applying appropriate security controls based on the traffic's origin and destination.

These access control and policy enforcement functions operate continuously during product operation, evaluating every administrative command against authorization policies and inspecting network traffic against configured security rules.

The integrity of these functions directly determines the product's ability to maintain secure network boundaries and prevent unauthorized configuration changes that could compromise network security.

9.2.4 Configuration and management

Configuration and management functions provide interfaces for product administration including command-line interfaces, web-based management, and programmatic APIs. These functions handle network interface settings, routing protocol parameters, security policies, quality of service rules, and system maintenance operations. Configuration systems maintain consistency across redundant components and protect stored configurations against corruption or unauthorized modification.

9.2.5 Monitoring and diagnostics

Monitoring functions collect interface statistics, error conditions, performance metrics, and security events. These capabilities provide visibility into product operation, network traffic patterns, and potential security incidents. Diagnostic features enable troubleshooting of connectivity issues, performance problems, and configuration errors while managing the exposure of sensitive operational information.

9.3 Operational environment

The technical requirements of the present document apply to products operating within their intended deployment conditions. Products shall comply with applicable technical requirements when operating within the boundaries defined by their intended use.

Routers, modems intended for connection to the internet, and switches operate in diverse physical and logical environments that influence their security requirements and threat exposure. Physical environments range from data centers with restricted access to residential settings with minimal physical security, and outdoor deployments exposed to potential tampering. Logical environments encompass the network architectures, trust boundaries, and interconnected systems that define the operational context.

These products typically operate continuously with occasional planned downtime, processing traffic flows between networks with varying trust levels. They may connect directly to untrusted public networks, as well as bridge between networks with different security classifications. The operational environment includes adjacent network products, upstream service provider products, downstream client systems, and management infrastructure that collectively form the extended attack surface.

Security considerations for these products typically include the management plane security and how administrative access is controlled, the robustness of protocol implementations against malformed inputs and attacks, the integrity of boot processes and software update mechanisms, the containment of potential breaches through isolation and segmentation capabilities, and finally the protection against physical tampering or unauthorized physical access.

9.4 User categories and access context

Routers, modems intended for connection to the internet, and switches interact with different categories of users who have varying levels of access and technical capability.

Professional network administrators configure and maintain these products as part of their primary responsibilities. They possess the technical knowledge to implement security policies, analyse logs, and respond to incidents. Their privileged access to product functions requires strong authentication and accountability measures.

Service provider personnel install and maintain customer premises equipment, particularly in managed service environments. Their access typically focuses on service provisioning and troubleshooting functions while customer data and certain security settings should remain restricted. This split access model reflects the shared responsibility between service providers and their customers.

End users in homes and small offices may interact with product configuration through simplified interfaces. These users often lack security expertise and may unknowingly create vulnerabilities through weak passwords or misconfiguration. Consumer products increasingly attempt to balance usability with security through automated updates and secure defaults.

Management systems and orchestration platforms interact with products through programmatic interfaces for configuration automation and monitoring. These automated systems require the same authentication and audit controls as human users since compromise of these systems can affect multiple products simultaneously.

Management systems and orchestration platforms interact with products through programmatic interfaces for configuration automation and monitoring. These automated systems require the same authentication and audit controls as human users since compromise of these systems can affect multiple products simultaneously.

9.5 Product security context summary

The diverse operational contexts, deployment scenarios, and functional requirements described in this chapter demonstrate that routers, modems intended for connection to the internet, and switches cannot be secured through a uniform set of requirements applied indiscriminately across all implementations. These products operate in environments ranging from physically secured data centers with professional administration to residential settings with minimal technical oversight and no physical access controls. They serve networks processing everything from casual home internet traffic to critical infrastructure control systems where availability directly impacts public safety.

The analysis presented in this chapter reveals several critical dimensions that influence security requirements. Products deployed with internet-exposed management interfaces face fundamentally different threats than those accessible only through physical console ports. Centrally managed products can receive coordinated security updates within hours of vulnerability disclosure, while individually administered devices may operate for months or years with known vulnerabilities due to manual update processes. The value of assets protected, ranging from personal browsing data to financial transactions and industrial control systems, directly correlates with the sophistication and persistence of attackers targeting these products.

These contextual factors establish the technical foundation for the conditional applicability model presented in clause 5. The security measures necessary to protect a carrier-grade router processing millions of subscriber connections differ substantially from those appropriate for a small office switch with local management only. By understanding the operational contexts, threat exposures, and deployment constraints inherent to different implementations, the subsequent chapters can specify security requirements that provide appropriate protection without imposing unnecessary complexity or cost on implementations where such measures would provide no security benefit.

The comprehensive understanding of product context presented in this chapter therefore enables the risk-based approach to security requirements that follows, ensuring that each product implementation receives security controls proportionate to its actual threat exposure and operational constraints rather than theoretical risk assessments disconnected from deployment reality

10 Annex D (informative): Threat landscape and security considerations

10.1 General

This clause provides the threat and vulnerability analysis that informed the development of the condition-based security requirements specified in the present document. The analysis examines threat actors, vulnerability patterns, and attack scenarios relevant to routers, modems intended for connection to the internet, and switches to establish the technical foundation for the proportionate application of security requirements based on product capabilities and deployment contexts. The evaluation demonstrates how specific conditions defined in clause **Error! Reference source not found.** correspond to different threat exposures and attack surfaces. This relationship between conditions and threats justifies why certain capabilities trigger enhanced security requirements while maintaining baseline protections for all products regardless of configuration or deployment.

The threat and vulnerability analysis presented in this clause follows a structured methodology that evaluates threats across three dimensions: threat actor capabilities and motivations, vulnerability prevalence and exploitability, and deployment-specific risk factors. This multi-dimensional analysis produces a threat severity matrix that directly informs the classification of security requirements as either universal (applying to all products) or conditional (applying only when specific conditions are present).

The analysis distinguishes between baseline threats that affect all routers, modems intended for connection to the internet, and switches regardless of their configuration, and elevated threats that emerge only in specific deployment contexts or with certain capabilities enabled. Baseline threats include opportunistic automated attacks seeking default credentials, supply chain compromises affecting firmware integrity, and physical tampering in environments with inadequate access controls. These universal threats justify the core security requirements specified without conditions in clauses 6 and 7.

Elevated threats correspond directly to the conditions defined in clause **Error! Reference source not found.**, with each condition introducing specific attack vectors and threat actors. The analysis demonstrates that products with internet-exposed management interfaces (condition [NE-4]) face threat volumes that are higher than those with only physical management access (condition [NE-1]). Similarly, products under centralized management (condition [MM-2]) present different vulnerabilities than individually managed devices (condition [MM-1]), though both models introduce distinct security challenges requiring tailored controls.

This threat-driven approach ensures that security requirements remain proportionate to actual risk while avoiding both under-protection of high-risk deployments and over-engineering of low-risk implementations. The mapping between threats and requirements is traceable throughout the document, with each requirement in clauses 6 and 7 addressing specific threats identified in this analysis

10.2 Threat agent characterization

Threat agents targeting routers, modems intended for connection to the internet, and switches exhibit predictable patterns of behaviour based on their technical capabilities, resource constraints, and objectives. This characterization employs a capability-intent that maps threat actors against the conditions defined in clause **Error! Reference source not found.**, establishing quantifiable relationships between deployment configurations and threat exposure levels.

The analysis considers both the technical sophistication required to execute specific attacks and the economic incentives driving different threat actors. This economic perspective is critical for understanding why certain deployment configurations attract disproportionate attention from attackers. Products with public network-exposed management interfaces represent targets with favourable attack economics, where single vulnerabilities can be monetized across millions of devices through automated exploitation. Conversely, products accessible only through physical interfaces require threat actors to accept unfavourable economics, limiting attacks to high-value targets or opportunistic scenarios.

10.2.1 Threat distribution across network exposure levels

Products within the scope of the present document face exploitation attempts from four primary threat agent categories, each possessing distinct capabilities and targeting different vulnerability classes.

Script-based automated tools represent the highest volume threat, continuously scanning public network-exposed products for default credentials, unpatched vulnerabilities, and misconfigurations. These tools operate without human intervention, attempting exploitation at scale across millions of products daily. Their success relies on the persistent

presence of basic security failures in deployed products. This threat category particularly affects products with [NE-4] condition, where automated scanning can identify and exploit vulnerable management interfaces within minutes of exposure.

Targeted attackers who have gained initial foothold within organizational networks pose the primary threat to products with condition [NE-3]. These adversaries, having breached perimeter defenses through phishing, supply chain compromise, or exploitation of internet-facing services, systematically map internal networks to identify critical infrastructure. Network products with remote management capabilities become priority targets for establishing persistent access and intercepting traffic flows. The controlled network boundaries that characterize [NE-3] products provide some protection against external scanning but offer limited defense once attackers operate from within the trusted network perimeter.

Insider threats and compromised local systems represent the dominant risk for products with condition [NE-2]. Malicious insiders or malware operating on compromised workstations within the same network segment can directly interact with management interfaces that would otherwise be protected from remote access. These threats bypass network segmentation controls by operating from within the same broadcast domain as the target product. Additionally, lateral movement techniques employed by advanced malware specifically target network infrastructure on the local segment to avoid detection by network monitoring systems that focus on routed traffic.

Physical security breaches constitute the sole direct threat vector for products with condition [NE-1]. These threats range from opportunistic attackers with momentary physical access attempting password recovery procedures, to sophisticated adversaries installing hardware implants or extracting firmware for reverse engineering. Cleaning staff, maintenance personnel, and other individuals with legitimate physical access but lacking authorization for product administration represent a insider threat that cannot be mitigated through network security controls. The complete absence of network-based management interfaces eliminates remote attack vectors but concentrates risk on physical security controls that may be inadequate in many deployment environments.

10.2.2 Threat patterns associated with management models

The management model employed for routers, modems intended for the connection to the internet, and switches fundamentally influences their threat exposure and the sophistication of attacks they face. Different management approaches create distinct vulnerability patterns that attract specific categories of threat actors with varying objectives and capabilities.

Products with condition [MM-1], where products are administered directly by end users or local IT staff without integration into network management systems, face a threats characterized by inconsistent security practices and limited visibility. These independently managed products attract opportunistic attackers who exploit common misconfigurations resulting from manual administration processes. The absence of centralized management creates environments where security updates may be delayed or overlooked entirely, with each product potentially maintaining different patch levels and security configurations. Insider threats pose risks in these deployments, as the lack of centralized logging and monitoring makes unauthorized configuration changes difficult to detect. Additionally, the reliance on individual product management often results in weaker credential management practices, including password reuse across products and retention of default or weak administrative credentials. Social engineering attacks targeting individual administrators prove particularly effective in these environments, as there are typically no systematic controls to prevent or detect unauthorized access gained through compromised credentials.

Organized cybercrime groups employ more sophisticated techniques, developing custom exploits for zero-day vulnerabilities and maintaining persistent access to compromised infrastructure. Products with condition [MM-2] present attractive targets due to their potential for accessing multiple customer networks through compromised management systems.

10.2.3 Threats arising from capability-based conditions

Products implementing specific protocol capabilities face distinct threat patterns based on the inherent security limitations of these protocols. These threats persist regardless of deployment context, as they arise from fundamental protocol design rather than configuration or exposure level.

Products with condition [PS-1] implementing cleartext management protocols face credential harvesting threats from any position along the network path. Attackers with access to network traffic through ARP spoofing, compromised intermediate devices, or network taps can capture authentication credentials and configuration commands in real-time. These captured credentials enable complete device compromise without requiring vulnerability exploitation. The persistence of these protocols in production environments, driven by legacy system compatibility and operational constraints, ensures continued viability of passive interception attacks.

- 1922 Condition [PS-2] creates opportunities for request injection and state manipulation attacks. Products accepting
1923 unauthenticated protocol requests cannot distinguish between legitimate and malicious sources, enabling attackers to
1924 inject false information that corrupts operational state. These attacks require only network adjacency rather than
1925 authenticated access, significantly expanding the potential attacker population to include any compromised endpoint
1926 within the broadcast domain.
- 1927 Products with condition [PS-3] face information disclosure threats that enable reconnaissance for subsequent targeted
1928 attacks. Unauthenticated diagnostic and discovery protocols provide attackers with topology maps, firmware versions,
1929 configuration details, and operational status without triggering authentication failures that might generate security alerts.
1930 This reconnaissance capability allows attackers to identify specific vulnerabilities, understand network relationships,
1931 and plan attack paths while remaining undetected. The legitimate operational use of these protocols makes
1932 distinguishing malicious reconnaissance from normal network operations particularly challenging.
- 1933 Condition [PS-4] exposes products to cryptographic downgrade attacks where attackers force communication using the
1934 weakest supported protocol version. The requirement to maintain backward compatibility with legacy systems means
1935 products must accept connections using deprecated security mechanisms with known vulnerabilities. Attackers exploit
1936 this by preventing negotiation of stronger protocols, forcing communication through compromised cryptographic
1937 channels. The extended lifecycles of network infrastructure ensure this legacy protocol versions remain enabled far
1938 beyond their security viability period.
- 1939 Products implementing protocols with condition [PS-5] face trust manipulation attacks where adversaries exploit the
1940 absence of cryptographic verification to inject false trust relationships. Without authentication of protocol peers,
1941 attackers can claim false identities, advertise bogus capabilities, or establish rogue adjacencies that appear legitimate to
1942 the protocol state machine. These attacks are particularly effective because they operate within the normal protocol
1943 behavior, making detection through anomaly analysis difficult. The automatic trust establishment inherent in these
1944 protocols means successful attacks often persist until manual intervention.
- 1945 The compound effect when products implement multiple protocol conditions creates elevated threat scenarios. Products
1946 with both [PS-1] and [PS-2] conditions enable attack chains where captured credentials from cleartext protocols
1947 facilitate injection attacks through unauthenticated interfaces. Similarly, reconnaissance through [PS-3] protocols
1948 identifies systems with [PS-4] weaknesses, enabling targeted cryptographic exploitation. These interactions demonstrate
1949 that protocol-based threats cannot be evaluated in isolation but must consider the aggregate attack surface created by
1950 multiple protocol implementations.
- 1951 The operational requirement to support these protocols for compatibility, interoperability, and legacy system support
1952 ensures these threats persist despite known vulnerabilities. Unlike software vulnerabilities that can be patched, protocol-
1953 based threats arise from fundamental design decisions that cannot be remediated without breaking compatibility. This
1954 permanence of protocol-based threats necessitates compensating controls rather than direct remediation, influencing the
1955 security requirements that must address these conditions through alternative protective measures.
- 1956 **10.2.4 Advanced persistent threats and emerging attack vectors**
- 1957 **10.2.4.1 Nation-state actors and Advanced Persistent Threat groups**
- 1958 Nation-state actors and Advanced Persistent Threat (APT) groups represent the most sophisticated and persistent threat
1959 category targeting network infrastructure. These actors possess substantial resources, including dedicated exploit
1960 development teams, zero-day vulnerability stockpiles, and the operational capability to maintain presence in target
1961 networks for extended periods measured in years rather than days or weeks.
- 1962 Particularly routers and switches, represent high-value targets for nation-state actors due to their strategic position
1963 enabling mass surveillance, traffic interception, and potential disruption of critical services.
- 1964 The threat from nation-state actors varies significantly based on deployment context and geographic factors. Products
1965 deployed in critical infrastructure, government networks, or telecommunications providers face elevated targeting
1966 compared to residential deployments. However, nation-state actors increasingly compromise residential and small
1967 business equipment to create distributed infrastructure for subsequent operations, making even consumer-grade
1968 products potential targets.
- 1969 Products with condition [NE-4] face particular risk from nation-state scanning and exploitation infrastructure that
1970 operates at global scale, automatically identifying and cataloging vulnerable devices for potential future operations.
1971 Products with condition [MM-2] present attractive targets due to the potential for supply chain compromise of
1972 management infrastructure, enabling simultaneous access to numerous managed devices across multiple organizations.

1973 10.2.4.2 Supply chain infiltration threats

1974 Supply chain attacks targeting network infrastructure represent an escalating threat vector that bypasses traditional
1975 security controls by compromising products before deployment. These attacks manifest across multiple stages of the
1976 product lifecycle, from component manufacturing through distribution channels to ongoing support and update
1977 mechanisms.

1978 Hardware supply chain threats include insertion of malicious components during manufacturing, modification of
1979 firmware during production or shipping, and substitution of legitimate products with compromised alternatives. The
1980 global nature of electronics manufacturing, with components sourced from multiple suppliers across different
1981 jurisdictions, creates numerous intervention opportunities for motivated adversaries.

1982 Software supply chain attacks target the development and distribution infrastructure used to create and deliver firmware
1983 updates. Compromise of build systems, code repositories, or update servers can result in widespread distribution of
1984 malicious firmware to deployed products.

1985 Third-party component vulnerabilities represent another supply chain risk dimension. Network products incorporate
1986 numerous third-party libraries, protocols stacks, and drivers, each potentially containing vulnerabilities unknown to the
1987 product manufacturer. The lag between vulnerability discovery in upstream components and downstream product
1988 updates creates windows of exposure that sophisticated actors actively exploit.

1989 Products under centralized management (condition [MM-2]) face elevated supply chain risks as compromise of the
1990 management infrastructure or update mechanisms can affect entire product fleets simultaneously. The trust relationship
1991 between managed devices and management platforms creates an attractive target for adversaries seeking to maximize
1992 impact through single-point compromises.

1993 10.2.4.3 Zero-day exploit markets and commercialization

1994 The commercialization of vulnerability research has created robust markets for zero-day exploits targeting network
1995 infrastructure. These markets include legitimate security research, gray market brokers selling to governments and law
1996 enforcement, and criminal marketplaces trading exploits for financial gain. The economic incentives driving these
1997 markets ensure continuous discovery and weaponization of vulnerabilities in network products.

1998 Exploit prices for network infrastructure vulnerabilities, particularly those enabling remote code execution without
1999 authentication, command premium prices exceeding those for endpoint exploits. Router and switch exploits are
2000 particularly valuable due to their potential for persistent access, traffic interception, and difficulty of detection.

2001 The proliferation of exploit development frameworks and toolkits has lowered barriers to entry for creating reliable
2002 exploits from published vulnerability information. Proof-of-concept code published by security researchers is rapidly
2003 weaponized and integrated into automated exploitation tools, reducing the time between disclosure and widespread
2004 exploitation to hours or days.

2005 Products with network exposure condition [NE-4] face immediate targeting when vulnerabilities are disclosed, as
2006 automated scanning and exploitation tools are updated within hours to include new exploits. The global accessibility of
2007 public network-exposed management interfaces means that every disclosed vulnerability immediately becomes
2008 actionable for attackers worldwide, regardless of their sophistication level.

2009 10.3 Vulnerability analysis

2010 The vulnerability landscape for routers, modems intended for connection to the internet, and switches reflects both the
2011 inherent complexity of network protocol implementations and the operational constraints under which these products
2012 function. These products must process untrusted input at wire speed while maintaining compatibility with diverse
2013 network environments. This fundamental tension between performance, compatibility, and security creates vulnerability
2014 patterns that persist across vendors and product generations.

2015 Vulnerability analysis for these products requires examination across multiple layers, from hardware-level
2016 vulnerabilities exploitable through physical access to application-layer flaws in management interfaces. The analysis
2017 must consider not only the technical characteristics of vulnerabilities but also their exploitability under different
2018 deployment conditions. A memory corruption vulnerability in a management interface poses minimal risk when that
2019 interface is accessible only through a serial console but becomes critical when exposed to public network-based attacks.
2020 This context-dependent risk assessment drives the conditional application of security requirements, ensuring that
2021 protective measures align with actual exploitability rather than theoretical severity.

2022 10.3.1 Attack scenario analysis

2023 The combination of threat actors and vulnerabilities creates specific attack scenarios that vary based on product
2024 capabilities and deployment contexts. These scenarios demonstrate how different conditions create distinct risk profiles
2025 requiring proportionate security controls.

2026 For products with network exposure condition [NE-4] combined with management model [MM-1], the dominant attack
2027 pattern involves automated exploitation followed by persistent compromise. The attack begins with public network-
2028 wide scanning identifying the product through banner information or behavioral fingerprinting. Automated tools
2029 attempt authentication using databases of default credentials, with successful authentication immediately followed by
2030 configuration modification to establish persistence. The attacker typically disables logging, creates additional
2031 administrative accounts with innocuous names, and modifies firewall rules to ensure continued access. The
2032 compromised device subsequently downloads and executes malware that enrolls it in a botnet infrastructure while
2033 maintaining normal routing functionality to avoid detection.

2034 Products operating under condition [NE-3] with [MM-2] face targeted attacks focused on achieving lateral movement
2035 within organizational networks. These attacks may begin with initial compromise of user workstations through phishing
2036 or watering hole attacks. Once established within the organizational network, attackers perform systematic
2037 reconnaissance to identify network infrastructure, specifically searching for management interfaces and analyzing
2038 traffic patterns to identify management protocols. The attack progresses through exploitation of the management
2039 interface and may leverage legitimate but misconfigured access controls or exploiting vulnerabilities in the management
2040 protocol implementation. Successful compromise provides attackers with the ability to monitor traffic flows, redirect
2041 specific connections, and establish persistent backdoors for future access.

2042 The scenario for products with condition [NE-2] demonstrates the risks from compromised local systems and insider
2043 threats. In documented incidents, malware operating on compromised workstations within the same network segment
2044 identifies and targets network infrastructure through ARP scanning and service discovery. The malware exploits the
2045 implicit trust often granted to local network traffic, bypassing network-layer security controls that focus on routed
2046 traffic. Authentication attempts leverage credentials harvested from the compromised workstation, including browser-
2047 stored passwords, SSH keys, and cached authentication tokens. Successful authentication enables traffic interception,
2048 DNS manipulation, and establishment of covert channels that bypass network monitoring focused on north-south traffic.

2049 Physical attack scenarios relevant to condition [NE-1] reveal sophisticated techniques employed when network-based
2050 access is unavailable. Documented attacks include installation of hardware implants in the device's serial console path,
2051 providing remote access while appearing as legitimate console connections. Attackers with momentary physical access
2052 exploit password recovery procedures, often requiring only a simple key sequence during boot to gain administrative
2053 access. More sophisticated attacks may involve extraction and modification of firmware flash memory, inserting
2054 persistent backdoors that survive factory resets and firmware updates.

2055 10.3.2 Condition-based threat exposure

2056 The correlation between deployment conditions and successful exploitation demonstrates that threat exposure varies
2057 significantly based on product configuration and operational context. This analysis establishes the technical foundation
2058 for applying security requirements proportionally to actual risk rather than theoretical vulnerability severity.

2059 Products with network exposure condition [NE-4] experience fundamentally different threat dynamics than those with
2060 more restricted access. Public network-exposed management interfaces face continuous automated scanning and
2061 exploitation attempts from global threat actors. Any published vulnerability affecting products with this condition
2062 becomes immediately actionable for attackers worldwide, with exploitation tools rapidly incorporating new
2063 vulnerabilities as they are disclosed. The automated nature of these attacks means that vulnerable products can be
2064 compromised within hours or days of initial deployment when operating with factory default configurations. This high
2065 probability of compromise for internet-exposed products necessitates the enhanced authentication mechanisms,
2066 comprehensive logging, and rapid update capabilities specified for products with this condition.

2067 The threat exposure for products with condition [NE-3] reflects the reality of modern enterprise breaches where
2068 attackers operate from within organizational perimeters. Once adversaries establish presence within controlled networks
2069 through phishing, supply chain compromise, or exploitation of other vulnerabilities, products with condition [NE-3]
2070 become high-value targets for lateral movement and persistence. These products typically experience targeted rather
2071 than opportunistic attacks, with adversaries investing significant effort in reconnaissance and custom exploitation. The
2072 controlled network boundaries that characterize condition [NE-3] reduce exposure to automated scanning compared to
2073 condition [NE-4], but provide limited protection against sophisticated actors who have already breached perimeter
2074 defences. Products with condition [NE-3] involved in confirmed breaches often serve as pivot points for further network
2075 compromise, influencing the monitoring and logging requirements for this condition.

Products with condition [NE-2] face threats primarily from compromised endpoints and malicious insiders operating within the same network segment. The implicit trust often granted to local network traffic creates exploitable assumptions that adversaries leverage through ARP spoofing, broadcast exploitation, and abuse of link-local protocols. Successful exploitations of products with condition [NE-2] frequently originate from compromised workstations within the same broadcast domain, highlighting the importance of local network segmentation and endpoint security. The absence of routed access paths eliminates most potential attackers compared to public network-exposed configurations but concentrates risk on the subset of threats that successfully establish local network presence.

The most restricted configuration, condition [NE-1], eliminates network-based attack vectors entirely, limiting threats to those with physical access. This substantial reduction in attack surface significantly decreases exploitation probability compared to network-exposed products, but introduces unique risks from physical tampering, hardware implants, and insider threats with building access. Successful compromises of products with condition [NE-1] typically require either extended physical access periods or repeated brief access over multiple occasions, constraining the threat to specific adversary categories with appropriate operational capabilities and physical proximity.

The management model conditions create orthogonal risk dimensions that interact with network exposure conditions to produce compound effects. Products with condition [MM-2] benefit from centralized security operations that enable coordinated patch deployment and consistent security configuration across multiple devices. This centralized approach substantially reduces the window of vulnerability exposure compared to individually managed products. However, centralized management also introduces systemic risks where compromise of management infrastructure can affect numerous products simultaneously. Successful attacks against management platforms with condition [MM-2] can result in widespread compromise across entire product fleets, fundamentally different from the single-device compromises typical of condition [MM-1].

The temporal dimension of vulnerability exposure varies dramatically based on management model. Products with condition [MM-1] often exhibit inconsistent patch deployment patterns, with some devices receiving updates promptly while others remain unpatched for extended periods or throughout their operational lifetime. This persistent vulnerability exposure for individually managed products creates a population of exploitable devices that adversaries can reliably target long after patches become available. Conversely, products with condition [MM-2] demonstrate more consistent patch deployment patterns through automated or centrally coordinated update mechanisms, fundamentally altering the threat exposure timeline for these deployments.

The interaction between multiple conditions produces compound risk effects that justify the granular requirements structure. Products exhibiting both conditions [NE-4] and [MM-1] represent the highest risk category, combining maximum network exposure with minimal defensive capability and inconsistent patch management. In contrast, products with conditions [NE-1] and [MM-2] benefit from both reduced attack surface and professional security management. This significant variation in exploitation probability based on condition combinations validates the necessity of proportionate security requirements. Applying uniform security controls across all configurations would either leave high-risk deployments inadequately protected or impose unnecessary complexity on low-risk implementations where advanced security features provide no measurable benefit.

The analysis of condition-based threat exposure presented here directly informs the classification of security requirements in clauses 6 and 7. Requirements specified without conditions address threats present across all deployment scenarios, while conditional requirements target the specific elevated risks identified for each condition combination. This approach ensures that security controls align with actual exploitation patterns observed in production deployments rather than theoretical vulnerability assessments performed in isolation from operational reality. The clear relationship between deployment conditions and threat exposure provides the technical justification for the scaled security requirements that follow, ensuring that each product receives protection proportionate to its actual risk profile while avoiding unnecessary implementation burden for lower-risk configurations.

11 Annex E (informative): Risk assessment framework

11.1 General

This clause establishes the risk assessment framework that translates the threat and vulnerability analysis from clause **Error! Reference source not found.** into actionable risk determinations that inform the security requirements specified in clauses 6 and 7. While clause **Error! Reference source not found.** identifies what threats exist and how they manifest, this clause examines the broader risk dimensions that determine the actual likelihood and impact of security incidents in deployed products.

The risk assessment framework operates across multiple dimensions that extend beyond simple threat exposure to encompass operational, organizational, environmental, and systemic factors. These dimensions interact with the conditions defined in clause **Error! Reference source not found.** to create risk profiles that vary by orders of magnitude across different deployments. The framework demonstrates why uniform security requirements cannot adequately address the diverse risk landscape facing routers, modems intended for connection to the internet, and switches, thereby justifying the conditional applicability model implemented in this standard.

Risk in the context of network infrastructure products encompasses both the probability of successful compromise and the potential consequences when security failures occur. The CRA's requirement to ensure an appropriate level of cybersecurity based on risks necessitates examination of factors that influence both likelihood and impact. A product may face low probability of compromise due to restricted access but present high impact risk due to its critical position in network architecture. Conversely, products with high exposure to automated attacks may present limited impact if they operate in isolated segments with no sensitive data. The security requirements must therefore address both dimensions appropriately.

11.2 Primary risk dimensions

11.2.1 Compromise likelihood factors

The probability of successful compromise depends on the interaction between threat exposure, vulnerability presence, and defensive capabilities. Products with network exposure condition [NE-4] face continuous automated attacks from global adversaries, creating near-certainty of exploitation for any disclosed vulnerability. This exposure level, combined with the situation that many products operate with known vulnerabilities due to delayed or absent patching, creates baseline compromise probabilities that approach certainty over extended operational periods.

Management model conditions significantly influence compromise likelihood through their effect on patch deployment velocity and configuration consistency. Products under centralized management (condition [MM-2]) typically receive security updates within days of release, maintaining a minimal vulnerability window. Individual management (condition [MM-1]) often results in extended vulnerability exposure periods measured in months or years, fundamentally altering the probability calculations for successful exploitation.

Protocol implementation conditions significantly influence compromise probability independent of network exposure. Products with condition [PS-1] through [PS-5] carry inherent vulnerabilities that cannot be mitigated through patching or configuration alone. The presence of cleartext protocols, unauthenticated services, or deprecated cryptographic mechanisms creates baseline compromise risks that persist throughout the product lifecycle. These protocol-based vulnerabilities differ from software bugs in that they represent design-level exposures that must be accepted when the protocol is implemented, fundamentally altering the risk calculation for products requiring backward compatibility or interoperability with legacy systems.

The sophistication of available exploits represents another critical factor in compromise likelihood. Vulnerabilities that can be exploited through simple scripts experience immediate widespread exploitation, while those requiring sophisticated techniques may see limited exploitation despite theoretical severity. The commercialization of exploitation tools has lowered the barrier to entry for many attack techniques, expanding the pool of potential attackers capable of compromising network infrastructure.

11.2.2 Impact severity factors

The consequences of successful compromise extend across multiple dimensions that must be evaluated collectively to understand true impact severity. Network infrastructure products occupy positions where compromise can affect confidentiality, integrity, and availability simultaneously, with impacts cascading through dependent systems.

Data sensitivity directly influences impact severity, with products handling financial transactions, healthcare records, or industrial control communications presenting higher consequence risks than those processing general internet traffic.

The aggregation effect inherent to network infrastructure amplifies impact, as even individually low-sensitivity transactions achieve high collective value when millions traverse a single device. Products at aggregation points where multiple network segments converge face particularly high impact risks due to their visibility into diverse traffic flows.

The criticality of affected services determines the operational impact of compromise or disruption. Products supporting emergency services, critical infrastructure, or essential business operations present impact risks that extend beyond data loss to encompass threats to safety, economic stability, and social functioning. The interdependencies between network services mean that compromise of seemingly non-critical infrastructure can cascade into critical service disruptions through unexpected dependency chains.

11.2.3 Systemic and cascade risk factors

Network infrastructure products participate in complex systems where individual compromises can trigger cascading failures or enable systematic attacks across entire deployments. These systemic risks exceed simple additive effects, as compromised infrastructure can actively subvert security architectures designed with assumptions of trustworthy network components.

Products implementing dynamic routing protocols can, when compromised, manipulate routing tables across entire autonomous systems, redirecting traffic through attacker-controlled paths even when secure alternatives exist. Similarly, switches participating in spanning tree protocols can force network topology changes that may bypass security controls and monitoring points. These protocol-level manipulations demonstrate how individual product compromises can achieve impacts far exceeding their immediate network position.

The trust relationships inherent in network infrastructure create additional cascade risks. Many security architectures assume that infrastructure devices enforce policies correctly, with downstream systems trusting that traffic arriving from certain interfaces has passed appropriate security controls. When this trust is violated through infrastructure compromise, multiple security layers can be bypassed simultaneously, achieving impacts that would be impossible through direct attacks on end systems.

11.2.4 Temporal and lifecycle risk evolution

Risk profiles for routers, modems intended for connection to the internet, and switches evolve throughout their operational lifecycles despite the CRA requirement for manufacturers to provide security updates during the support period. The gap between vulnerability disclosure and patch deployment creates critical temporal risks, as operational constraints such as maintenance windows, compatibility testing, and change management procedures can delay update deployment by weeks or months even when patches are available.

This deployment gap varies significantly based on management model conditions. Products with condition [MM-2] benefit from centralized update mechanisms that enable rapid, coordinated patching across multiple devices. Products with condition [MM-1] require individual manual updates that may be delayed indefinitely due to resource constraints or lack of awareness, creating extended vulnerability windows despite manufacturer compliance with update requirements.

Products approaching end-of-support face escalating risks as organizations must balance operational disruption against security implications. While the CRA requires manufacturers to clearly communicate support periods, the operational reality of network infrastructure means products often operate up to and potentially beyond their support endpoints, creating predictable risk concentrations that adversaries can exploit.

The accumulation of vulnerabilities over time, even with regular patching, expands the attack surface as lower-severity issues may combine to create critical exploitation chains. These temporal factors directly justify the requirements in clause 6 for automated update capabilities, comprehensive update mechanisms, and clear security status communication, demonstrating that update availability alone is insufficient without mechanisms that minimize temporal vulnerability exposure.

11.2.5 Operational and organizational risk factors

The operational context in which products are deployed introduces risk factors independent of technical vulnerabilities. Organizations with mature security programs implement defense-in-depth strategies, security monitoring, and incident response capabilities that can detect and contain compromises quickly. These operational capabilities fundamentally alter the risk profile of deployed products, reducing both the likelihood of successful exploitation and the potential impact when compromises occur.

Conversely, organizations lacking security expertise or resources face elevated risks even when deploying products with strong security capabilities. The complexity of properly configuring network infrastructure security features exceeds the capabilities available in many deployments, creating persistent vulnerabilities that no amount of built-in security can fully address. This capability gap between security requirements and operational reality represents a fundamental risk factor that influences the practical effectiveness of security controls.

Physical security controls create another operational risk dimension, with products in secured facilities facing different threat profiles than those in publicly accessible locations. The assumption that physical access enables complete compromise remains valid for most network infrastructure, making physical security arrangements a critical risk factor that interacts with but remains distinct from network exposure conditions.

11.2.6 Risk assessment synthesis

The multi-dimensional risk assessment presented in this clause establishes that manufacturers face an inherent tension between market demands for product flexibility and the security implications of the capabilities that enable such flexibility. While manufacturers cannot control or predict where their products will be deployed, they make fundamental design decisions that determine which deployment scenarios become possible and, consequently, which risk exposures their products may face.

The present document reveals risks that correlates with the conditions defined in clause **Error! Reference source not found.** For example, products limited to physical access face risks primarily from insider threats and opportunistic attackers with physical access while products allowing public network management encounter global-scale automated attacks that operate continuously. Similarly, the implementation of protocols with known security limitations creates unavoidable risk exposures that must be balanced against operational requirements for compatibility and interoperability.

The economic reality that manufacturers must balance security-related costs against market competitiveness cannot be ignored. Additional security controls increase development complexity, production costs, and potentially impact product performance, all of which affect market viability. However, this risk assessment demonstrates that the absence of appropriate security controls in products with high-risk capabilities creates unacceptable vulnerabilities that can compromise entire network infrastructures. The conditional applicability model addresses this economic tension by requiring comprehensive security controls only for products whose capabilities enable high-risk deployment scenarios, avoiding unnecessary cost burdens for products with inherently limited risk exposure.

The temporal and operational risk factors examined in preceding sections demonstrate that security controls cannot eliminate all risks but rather reduce them to acceptable levels. Products with extensive capabilities retain higher residual risk even after implementing all required security controls. This residual risk persists because the fundamental attack surface created by remote management capabilities or centralized administration cannot be fully eliminated through security measures alone. Organizations deploying such products must understand and accept these inherent risk levels as part of their operational security posture.

Systemic risks influence which security requirements are necessary for these products. When products enable manipulation of routing protocols or spanning tree configurations, the compromise of a single device can undermine entire network security architectures. These cascade effects justify the enhanced security requirements specified for products with such capabilities, as early detection and containment become essential to prevent network-wide impacts.

For manufacturers, this risk assessment establishes a clear framework for evaluating the security implications of product capabilities. Each capability included in a product creates specific risk potentials through the conditions it enables, which trigger corresponding requirements. The Condition Assessment required by clause **Error! Reference source not found.** documents which conditions the product can create, ensuring transparency about the risk exposures that result from manufacturer design choices.

This risk assessment validates the proportionate approach implemented in the security requirements. The universal requirements in clauses 6 and 7 address baseline risks that persist regardless of product capabilities, while conditional requirements respond to specific risk elevations created by particular capabilities. The framework ensures that each

2267 product implements security measures appropriate to its actual risk potential as determined by its designed capabilities,
2268 achieving the CRA objective of cybersecurity proportionate to risks while maintaining economic viability across market
2269 segments

2270

11.2.6.1.1.1.1 Annex <L+1> (informative): Maximum measurement uncertainty

The annex is optional.

The measurements described in the present document are based on the following assumptions:

- the measured value related to the corresponding limit is used to decide whether an equipment meets the requirements of the present document;
- the value of the measurement uncertainty for the measurement of each parameter is included in the test report.

Table <L+1>.1 shows the recommended values for the maximum measurement uncertainty figures.

Table <L+1>.1: Maximum measurement uncertainty

Parameter	Uncertainty

2282 11.2.6.1.1.1.1.2 Annex <L+2> (normative or informative):
2283 Title of annex

2284 12 <L+2.1> First clause of the annex

2285 12.1 <L+2.1.1> First subdivided clause of the annex

2286 <Text>.

2287

2288

12.1.1.1.1.1.1.1.1 Annex <L+3> (informative):

2289

Bibliography

2290

<Publication>: "<Title>".<Edition>. <Year>, <Issue designation>, <Page location>.

2291

2292

12.1.1.1.1.1.2 Annex <L+4> (informative):

2293

Change history

2294

2295

2296

The "Change history/Change request (history)" annex shall be included in every revised or amended harmonised standard and shall contain information concerning significant changes that have been introduced by it. It shall be presented as a table.

Version	Information about changes

2299

13History

2300

The following table will automatically be filled in by the ETSI Secretariat.

Document history		

2301

2302

2303

Last update on 2025-06-19